

CCNA Security

Chapter Four

Implementing Firewall Technologies

Lesson Planning



- This lesson should take 3-6 hours to present
- The lesson should include lecture, demonstrations, discussion and assessment
- The lesson can be taught in person or using remote instruction

Major Concepts



- Implement ACLs
- Describe the purpose and operation of firewall technologies
- Implement CBAC
- Zone-based Policy Firewall using SDM and CLI

Lesson Objectives



Upon completion of this lesson, the successful participant will be able to:

1. Describe standard and extended ACLs
2. Describe applications of standard and extended ACLs
3. Describe the relationship between topology and flow for ACLs and describe the proper selection of ACL types for particular topologies (ACL design methodology)
4. Describe how to implement ACLs with SDM
5. Describe the usage and syntax for complex ACLs
6. Describe the usage and syntax for dynamic ACLs
7. Interpret the output of the show and debug commands used to verify and troubleshoot complex ACL implementations

Lesson Objectives



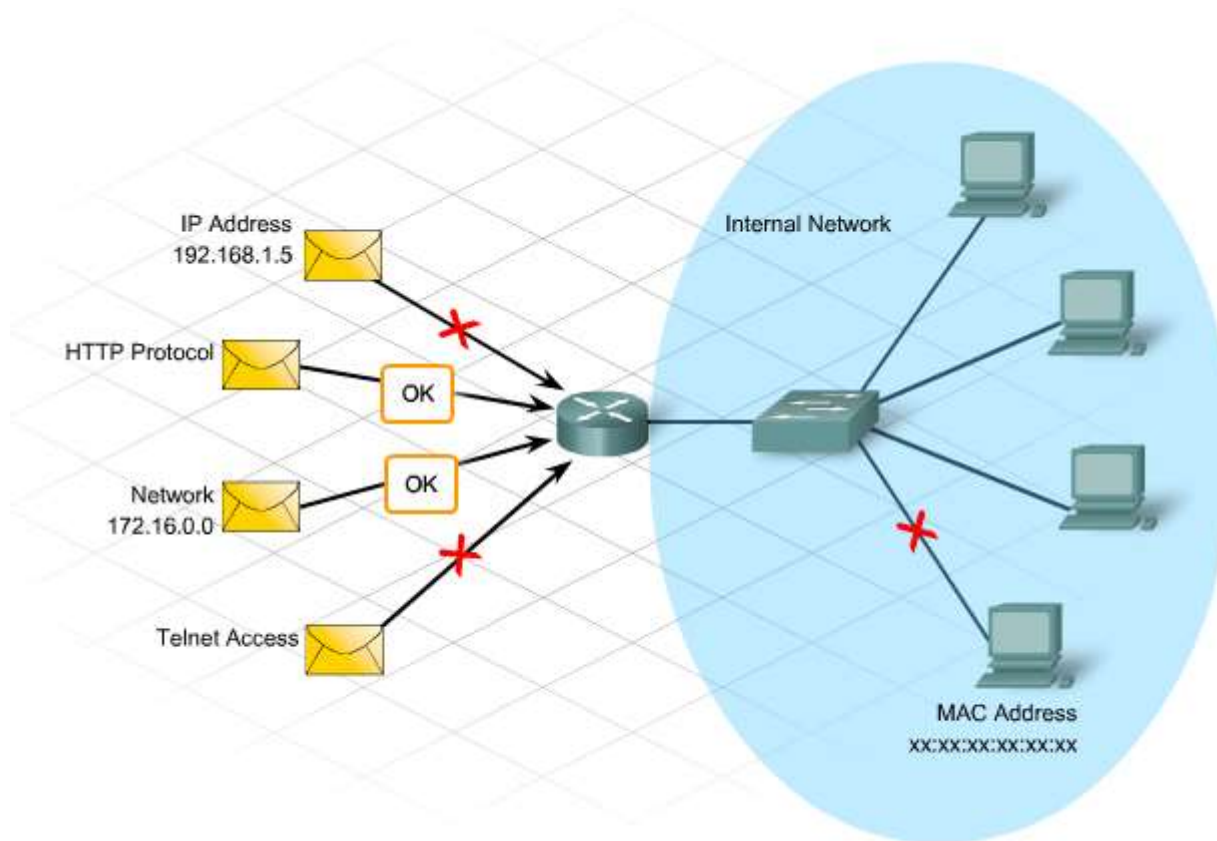
8. Describe how to mitigate common network attacks with ACLs
9. Describe the purpose of firewalls and where they reside in a modern network
10. Describe the various types of firewalls
11. Describe design considerations for firewalls and the implications for the network security policy
12. Describe the role of CBAC in a modern network
13. Describe the underlying operation of CBAC
14. Describe the configuration of CBAC
15. Describe the verification and troubleshooting of CBAC

Lesson Objectives



- 16. Describe the role of Zone-Based Policy Firewall in a modern network
- 17. Describe the underlying operation of Zone-Based Policy Firewall
- 18. Describe the implementation of Zone-Based Policy Firewall with CLI
- 19. Describe the implementation of Zone-Based Policy Firewall with manual SDM
- 20. Describe the implementation of Zone-Based Policy Firewall with the SDM Wizard
- 21. Describe the verification and troubleshooting of Zone-Based Policy Firewall

ACL Topology and Types



Protocol	Range
IP	1-99, 1300-1999
Extended IP	100-199, 2000-2699
Ethernet type code	200-299
Ethernet address	700-799
Transparent bridging (protocol type)	200-299
Transparent bridging (vendor code)	700-799
Extended transparent bridging	1100-1199
DECnet and extended DECnet	300-399
XNS	400-499
Extended XNS	500-599
AppleTalk	600-699
Source-route bridging (protocol type)	200-299
Source-route bridging (vendor code)	700-799
IPX	800-899
Extended IPX	900-999
IPX SAP	1000-1099
Standard VINES	1-100
Extended VINES	101-200
Simple VINES	201-300

Standard Numbered IP ACLs



```
Router(config)# access-list {1-99} {permit | deny}  
source-addr [source-mask]
```

- The first value specifies the ACL number
- The second value specifies whether to permit or deny the configured source IP address traffic
- The third value is the source IP address that must be matched
- The fourth value is the wildcard mask to be applied to the previously configured IP address to indicate the range
- All ACLs assume an implicit deny statement at the end of the ACL6+
- At least one permit statement should be included or all traffic will be dropped once that ACL is applied to an interface

Extended Numbered IP ACLs

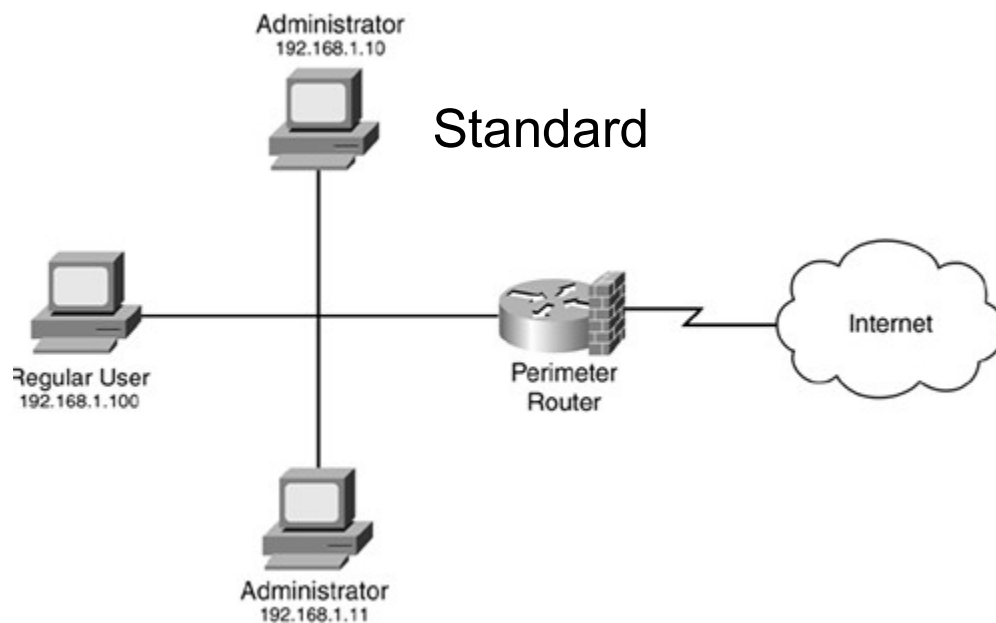


```
Router(config)# access-list {100-199} {permit | deny}  
protocol source-addr [source-mask] [operator operand]  
destination-addr [destination-mask] [operator operand]  
[established]
```

- The first value specifies the ACL number
- The second value specifies whether to permit or deny accordingly
- The third value indicates protocol type
- The source IP address and wildcard mask determine where traffic originates. The destination IP address and wildcard mask are used to indicate the final destination of the network traffic
- The command to apply the standard or extended numbered ACL:

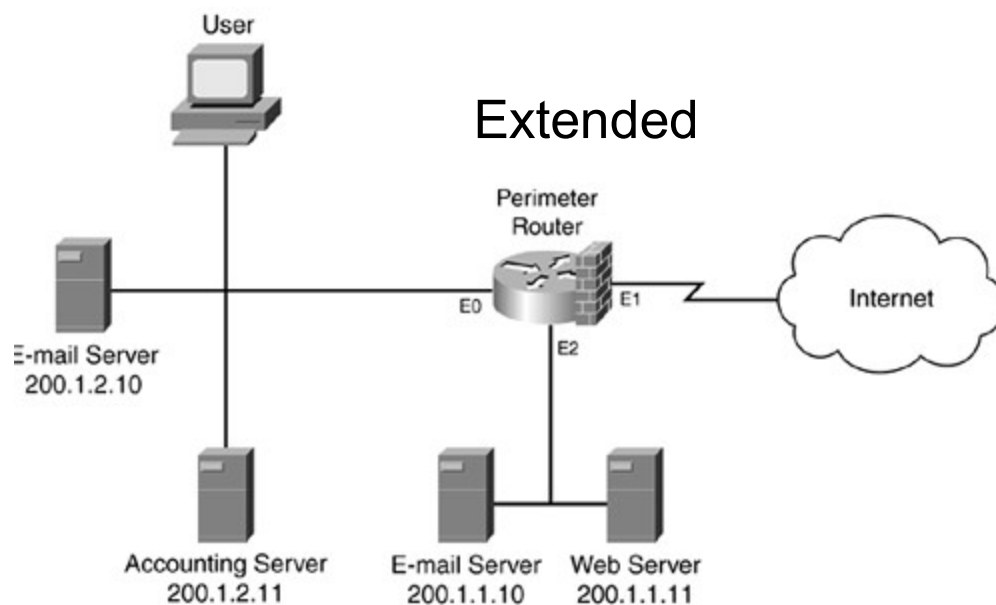
```
Router(config-if)# ip access-group number {in | out}
```

Named IP ACLs



```
Router(config)# ip access-list standard restrict_VTY
Router(config-std-nacl)# permit 192.168.1.10
Router(config-std-nacl)# permit 192.168.1.11
Router(config-std-nacl)# exit
Router(config)# line vty 0 4
Router(config-line)# access-class restrict_VTY in
```

```
Router(config)# ip access-list extended vachon1
Router(config-ext-nacl)# deny ip any 200.1.2.10
0.0.0.1
Router(config-ext-nacl)# permit tcp any host
200.1.1.11 eq 80
Router(config-ext-nacl)# permit tcp any host
200.1.1.10 eq 25
Router(config-ext-nacl)# permit tcp any eq 25 host
200.1.1.10 any established
Router(config-ext-nacl)# permit tcp any 200.1.2.0
0.0.0.255 established
Router(config-ext-nacl)# permit udp any eq 53
200.1.2.0 0.0.0.255
Router(config-ext-nacl)# deny ip any any
Router(config-ext-nacl)# interface ethernet 1
Router(config-if)# ip access-group vachon1 in
Router(config-if)# exit
```



The log Parameter



```
*May 1 22:12:13.243: %SEC-6-IPACCESSLOGP: list ACL-IPv4-E0/0-IN permitted tcp 192.168.1.3(1024) -> 192.168.2.1(22), 1 packet
```

```
*May 1 22:17:16.647: %SEC-6-IPACCESSLOGP: list ACL-IPv4-E0/0-IN permitted tcp 192.168.1.3(1024) -> 192.168.2.1(22), 9 packets
```

There are several pieces of information logged:

- The action—permit or deny
- The protocol—TCP, UDP, or ICMP
- The source and destination addresses
- For TCP and UDP—the source and destination port numbers
- For ICMP—the message types

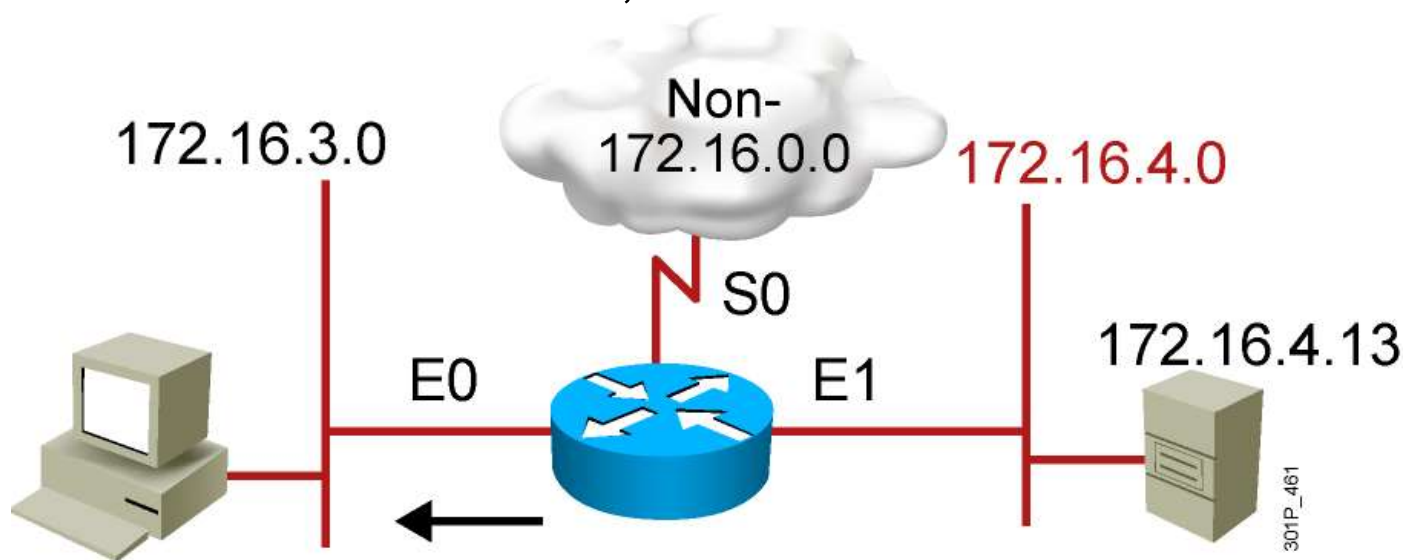
ACL Configuration Guidelines



- ACLs are created globally and then applied to interfaces
- ACLs filter traffic going through the router, or traffic to and from the router, depending on how it is applied
- Only one ACL per interface, per protocol, per direction
- Standard or extended indicates the information that is used to filter packets
- ACLs are process top-down. The most specific statements must go at the top of the list
- All ACLs have an implicit “deny all” statement at the end, therefore every list must have at least one permit statement to allow any traffic to pass

Applying Standard ACLs

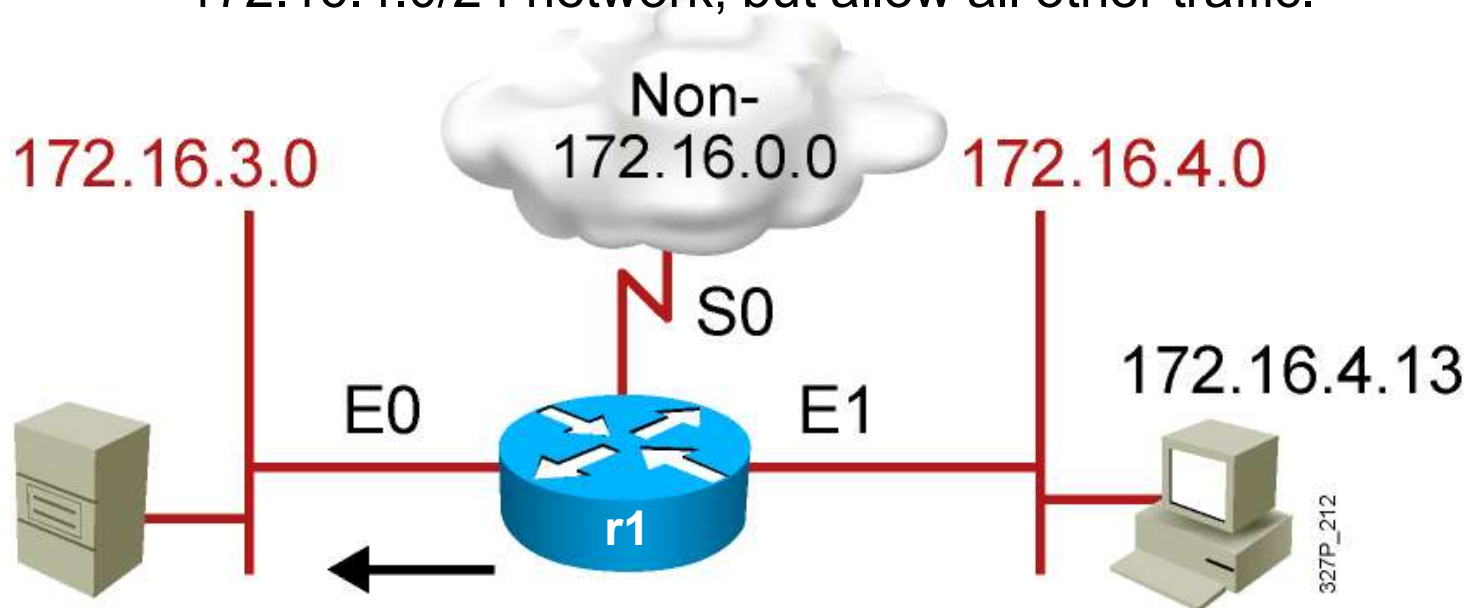
Use a standard ACL to block all traffic from 172.16.4.0/24 network, but allow all other traffic.



```
r1(config)# access-list 1 deny  
172.16.4.0 0.0.0.255  
r1(config)# access-list 1 permit any  
r1(config)# interface ethernet 0  
r1(config-if)# ip access-group 1 out
```

Applying Extended ACLs

Use an extended ACL to block all FTP traffic from 172.16.4.0/24 network, but allow all other traffic.



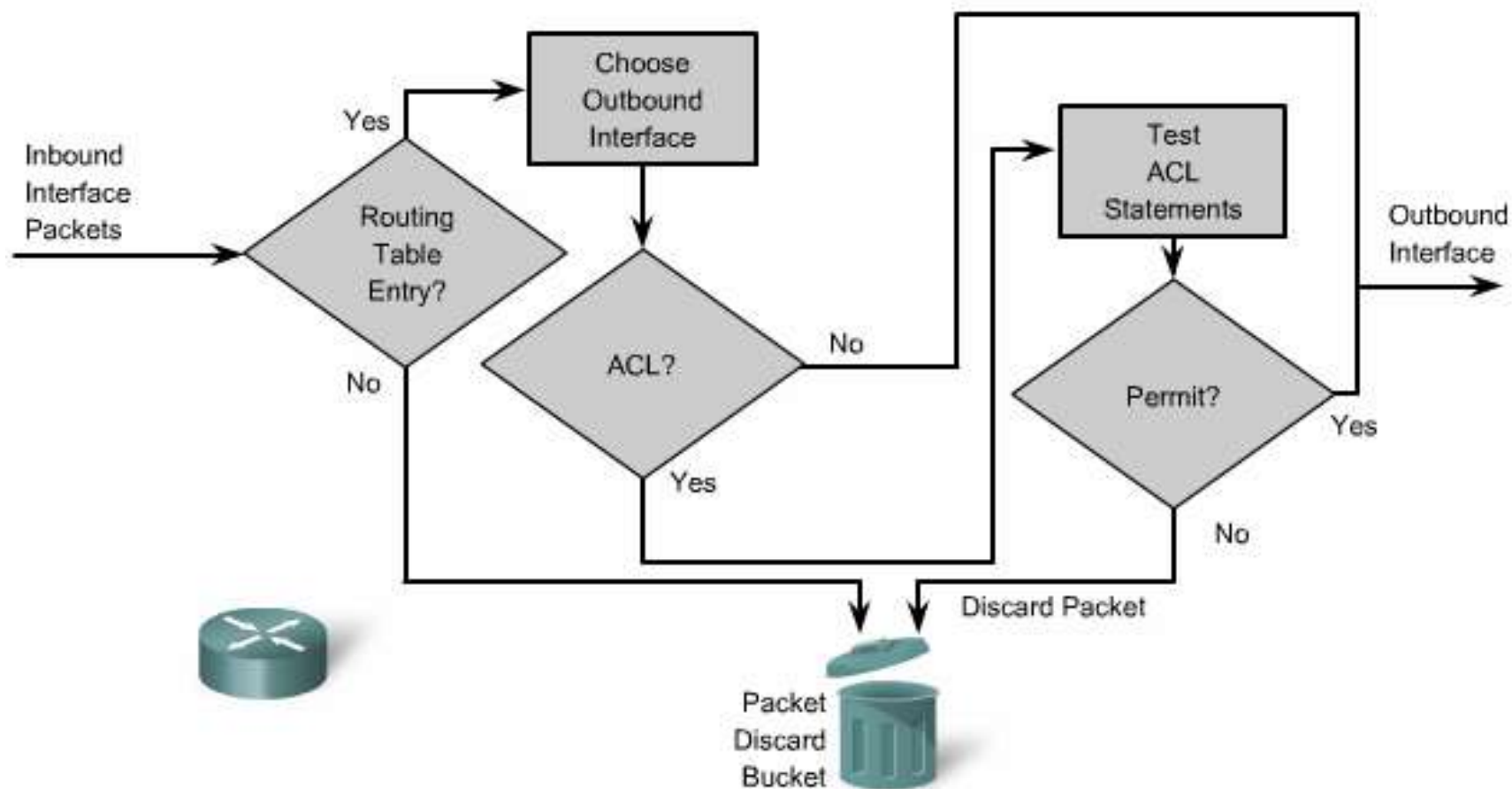
```
access-list 101 deny tcp 172.16.4.0 0.0.0.255  
172.16.3.0 0.0.0.255 eq 21  
access-list 101 deny tcp 172.16.4.0 0.0.0.255  
172.16.3.0 0.0.0.255 eq 20  
access-list 101 permit ip any any
```

Other CLI Commands



- To ensure that only traffic from a subnet is blocked and all other traffic is allowed:
access-list 1 permit any
- To place an ACL on the inbound E1 interface:
interface ethernet 1
ip access-group 101 in
- To check the intended effect of an ACL:
- **show ip access-list**

How ACLs Work

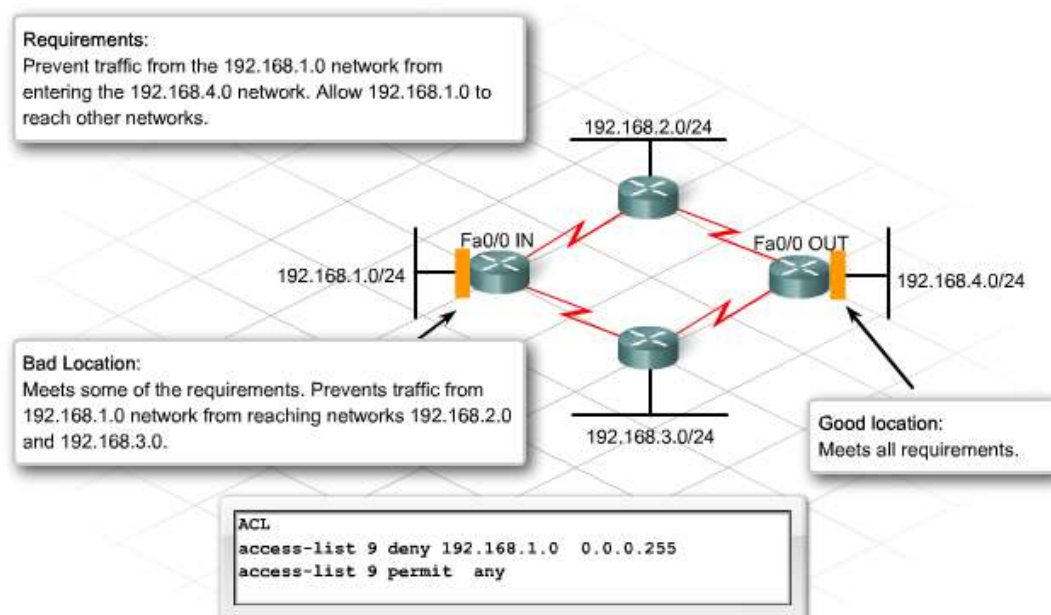


Inbound ACL

Outbound ACL

ACL Placement

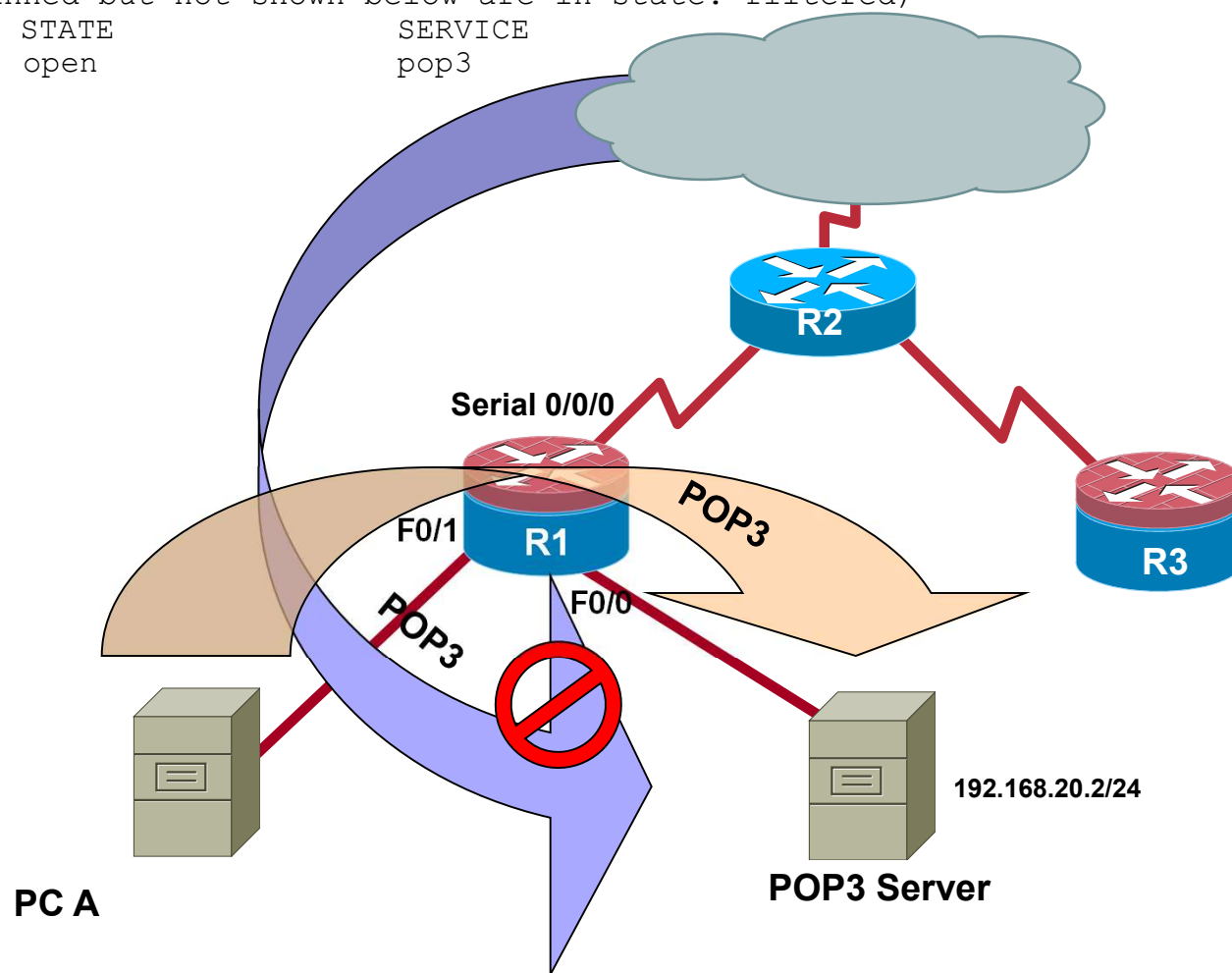
Standard ACLs should be placed as close to the destination as possible. Standard ACLs filter packets based on the source address only. If placed too close to the source, it can deny all traffic, including valid traffic.



Extended ACLs should be placed on routers as close as possible to the source that is being filtered. If placed too far from the source being filtered, there is inefficient use of network resources.

Using Nmap for Planning

```
PC-A$ nmap --system-dns 192.168.20.0/24
Interesting ports on webserver.branch1.com (192.168.20.2):
(The 1669 ports scanned but not shown below are in state: filtered)
PORT      STATE      SERVICE
110       open       pop3
```



Using SDM

Cisco Router and Security Device Manager (SDM): 10.0.151.1

File Edit View Tools Help

Home Configure Monitor Refresh Save Search Help

About Your Router Host Name:



Cisco 2811

Hardware	More...	Software	More...
Model Type:	Cisco 2811	IOS Version:	12.4(16)
Available / Total Memory(MB):	190/256 MB	SDM Version:	2.4
Total Flash Capacity:	61 MB		
Feature Availability: IP  Firewall  VPN  IPS  NAC 			

Configuration Overview View Running Config

Interfaces and Connections Up (3) Down (1)

Total Supported LAN:	2	Total Supported WAN:	2(Serial)
Configured LAN Interface:	2	Total WAN Connections:	1(HDLC)
DHCP Server:	Not Configured		

Firewall Policies Inactive

VPN Up (0)

IPSec (Site-to-Site):	0	GRE over IPSec:	0
Xauth Login Required:	0	Easy VPN Remote:	0
No. of DMVPN Clients:	0	No. of Active VPN Clients:	0

Routing

No. of Static Route:	0
Dynamic Routing Protocols:	EIGRP

Intrusion Prevention

Active Signatures:	0
No. of IPS-enabled Interfaces:	0
SDF Version:	

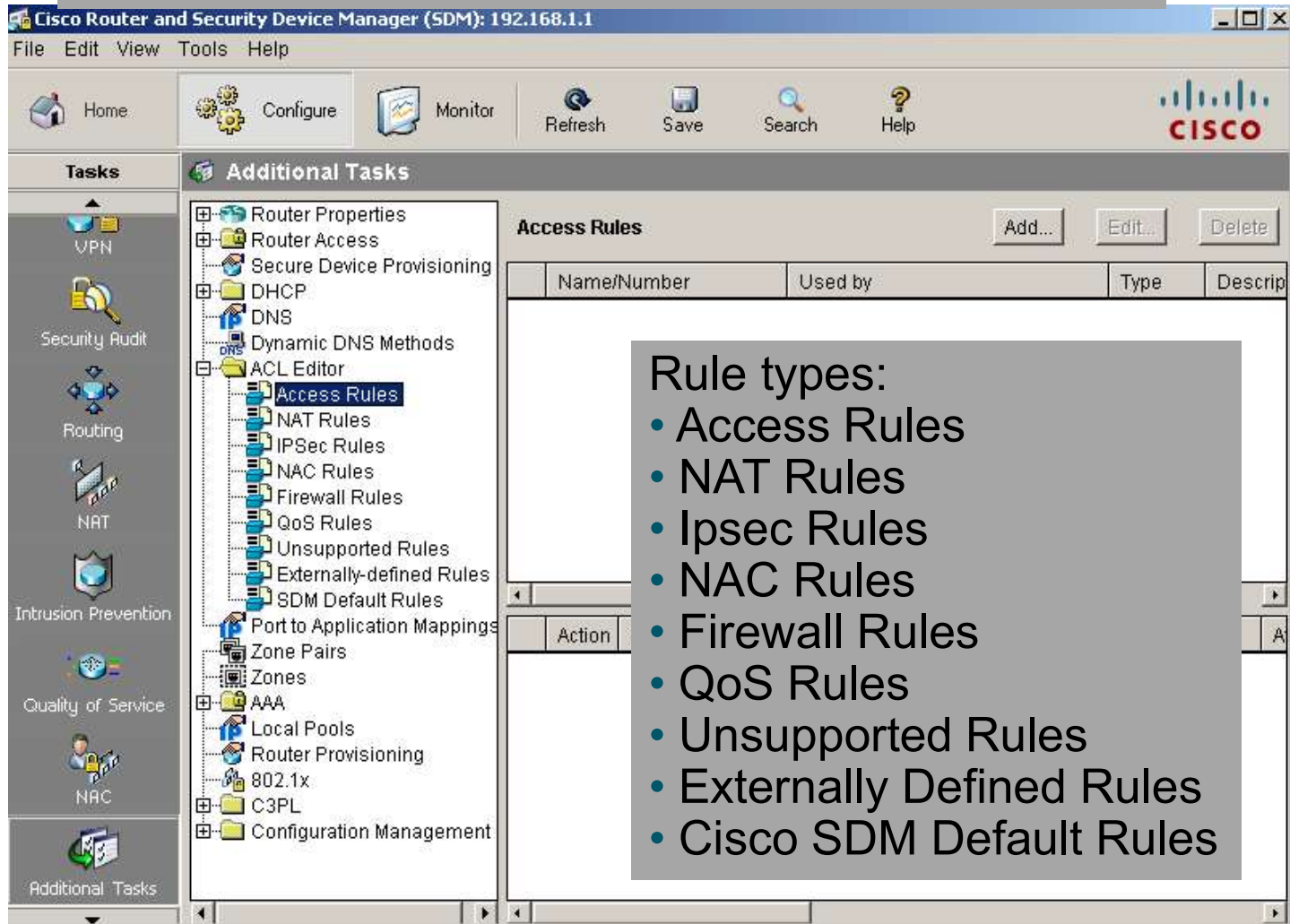
[Security Dashboard](#)

15:05:04 UTC Tue Oct 02 2007

Choose the Configure option for configuring ACLs

Access Rules

Choose Configure > Additional Tasks > ACL Editor



The screenshot shows the Cisco Router and Security Device Manager (SDM) interface. The title bar indicates the device IP is 192.168.1.1. The menu bar includes File, Edit, View, Tools, and Help. The main toolbar contains icons for Home, Configure, Monitor, Refresh, Save, Search, and Help. The left sidebar shows a tree of tasks, with 'Additional Tasks' expanded. Under 'Additional Tasks', the 'ACL Editor' folder is selected, and the 'Access Rules' sub-item is highlighted. The main pane displays the 'Access Rules' configuration area, which includes a table with columns: Name/Number, Used by, Type, and Description. The table is currently empty. A semi-transparent text box is overlaid on the right side of the interface, listing the available rule types.

Access Rules

Name/Number	Used by	Type	Descrip
-------------	---------	------	---------

Rule types:

- Access Rules
- NAT Rules
- Ipsec Rules
- NAC Rules
- Firewall Rules
- QoS Rules
- Unsupported Rules
- Externally Defined Rules
- Cisco SDM Default Rules

Configuring Standard Rules Using SDM

1. Choose Configure > Additional Tasks > ACL Editor > Access Rules

2. Click Add

3. Enter a name or number

4. Choose Standard Rule
Optionally, enter a description

5. Click Add

6. Choose Permit or Deny

7. Choose an address type

8. Complete this field based
on the choice made in #7

9. Enter an optional description

10. Optional checkbox

11. Click OK

12. Continue adding or editing rules

The image shows two overlapping dialog boxes from the Cisco SDM (Security Device Manager) interface. The 'Add a Rule' dialog is on the left, and the 'Add a Standard Rule Entry' dialog is on the right. The 'Add a Rule' dialog has a 'Rule Name' field with 'Outbound' entered, a 'Rule Type' dropdown set to 'Standard Rule', a 'Description' field, and a 'Rule Entry' list. The 'Add a Standard Rule Entry' dialog has an 'Action' dropdown set to 'Permit', a 'Type' dropdown set to 'A Host Name or IP Address', a 'Host Name/IP' field with '192.168.1.3' entered, and an optional description field. Both dialogs have 'Add...', 'Edit...', 'Delete', 'Move Up', and 'Move Down' buttons. The 'Add a Rule' dialog also has an 'Interface Association' section with 'None' and an 'Associate...' button. Both dialogs have 'OK', 'Cancel', and 'Help' buttons at the bottom.

Applying a Rule to an Interface

Add a Rule

Name/Number: Type:

Description:

Rule Entry

`permit host 192.168.1.3`

Add...
Clone...
Edit...
Delete
Move Up
Move Down

Interface Association

None. **Associate...**

OK Cancel

1. Click Associate

Associate with an Interface

Select an Interface:

2. Choose the interface

Specify a Direction:

☒ Inbound ☐ Outbound

3. Choose a direction

OK Cancel Help

4. An information box with options appears if a rule is already associated with that interface, that direction.

Viewing Commands

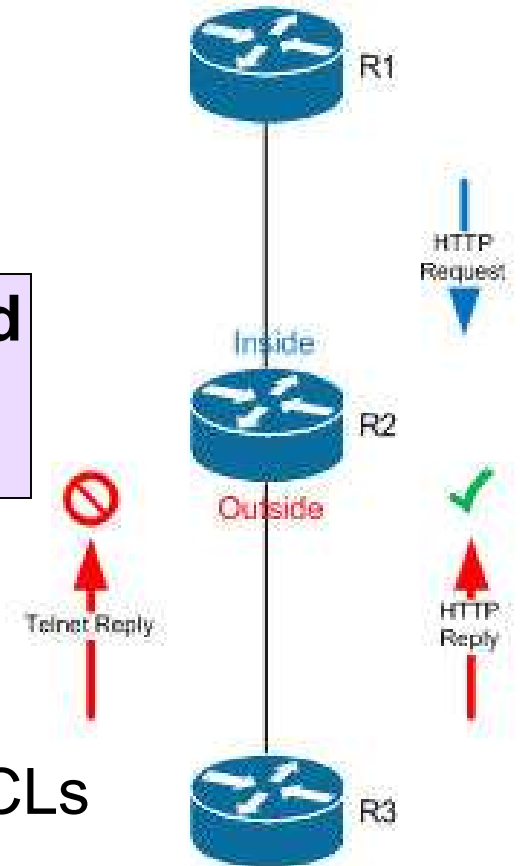


```
R1# show running-config
<output omitted>
!
hostname R1
<output omitted>
enable secret 5
    $1$MJD8$.1LWYcJ6iUi133Yg7vGHG/
<output omitted>
crypto pki trustpoint TP-self-signed-
    1789018390
    enrollmnt selfsigned
    subject-name cn=IOS-Self-Signed-
        Certificate-1789018390
    revocation-check none
    rsakeypair TP-self-signed-1789018390
!
crypto pki certificate chain TP-self-
    signed-1789018390
    certificate self-signed 01
        3082023A 308201A3 A0030201 02020101
        300D0609 2A864886 F70D0101 04050030
<output omitted>
        1BF29620 A084B701 5B92483D D934BE31
        ECB7AB56 8FFDEA93 E2061F33 8356
quit
```

```
interface FastEthernet0/1
    ip address 192.168.1.1 255.255.255.0
    ip access-group Outbound in
<output omitted>
!
interface Serial0/0/0
    ip address 10.1.1.1 255.255.255.252
    clock rate 128000
!
<output omitted>
no ip http server
ip http secure-server
!
ip access-list standard Outbound
    remark SDM_ACL Category=1
    permit 192.168.1.3
!
access-list 100 remark SDM_ACL Category=16
access-list 100 deny    tcp any host
    192.168.1.3 eq telnet log
access-list 100 permit ip any any
!
<output omitted>
!
```

Types of ACLs

- Standard IP ACLs
- Extended IP ACLs
- Extended IP ACLs using TCP **established**
- Reflexive IP ACLs
- Dynamic ACLs
- Time-Based ACLs
- Context-based Access Control (CBAC) ACLs



Syntax for TCP Established

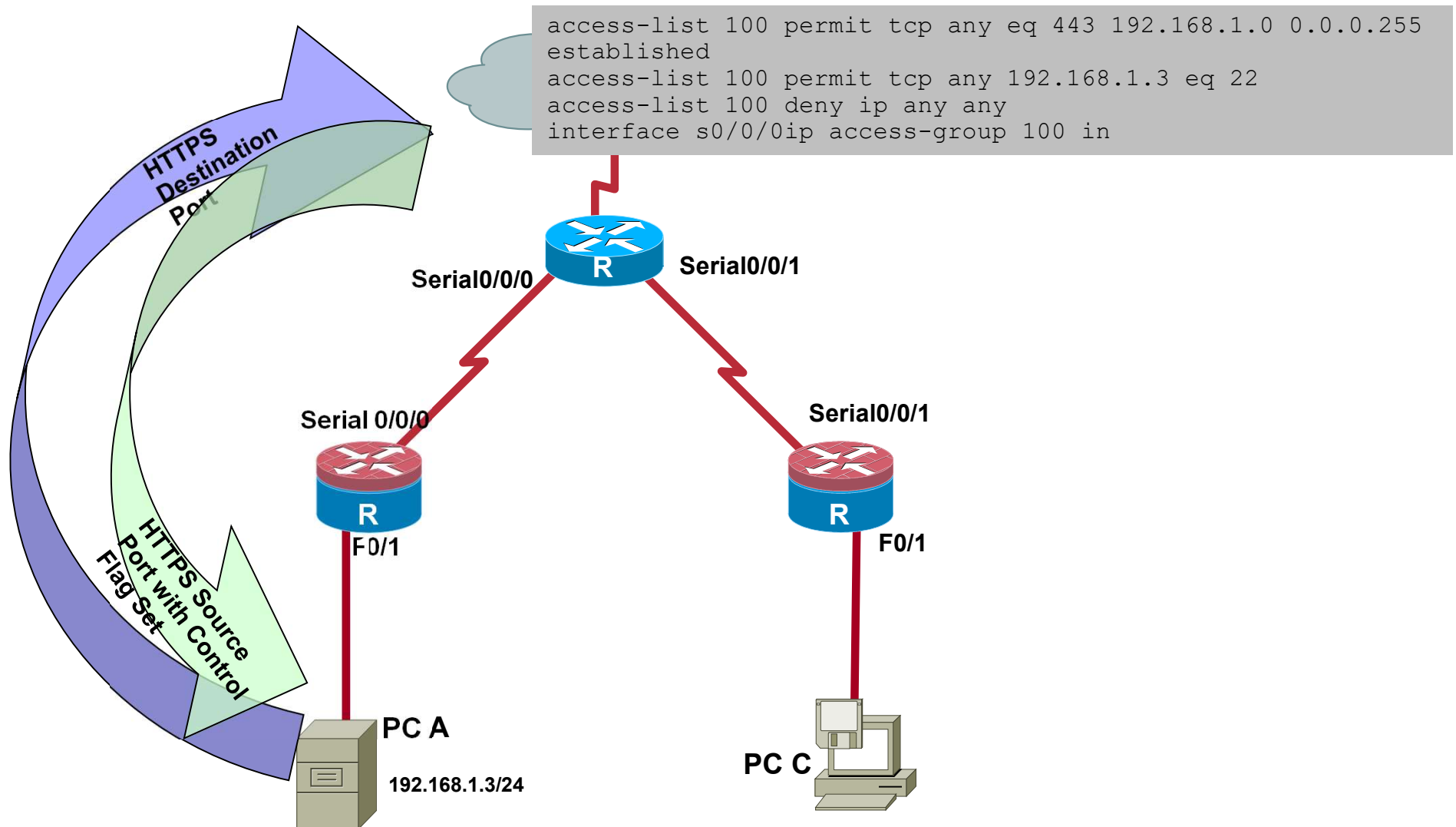


```
Router(config)# access-list access-list-number
{permit | deny} protocol source source-wildcard
[operator port] destination destination-wildcard
[operator port] [established]
```

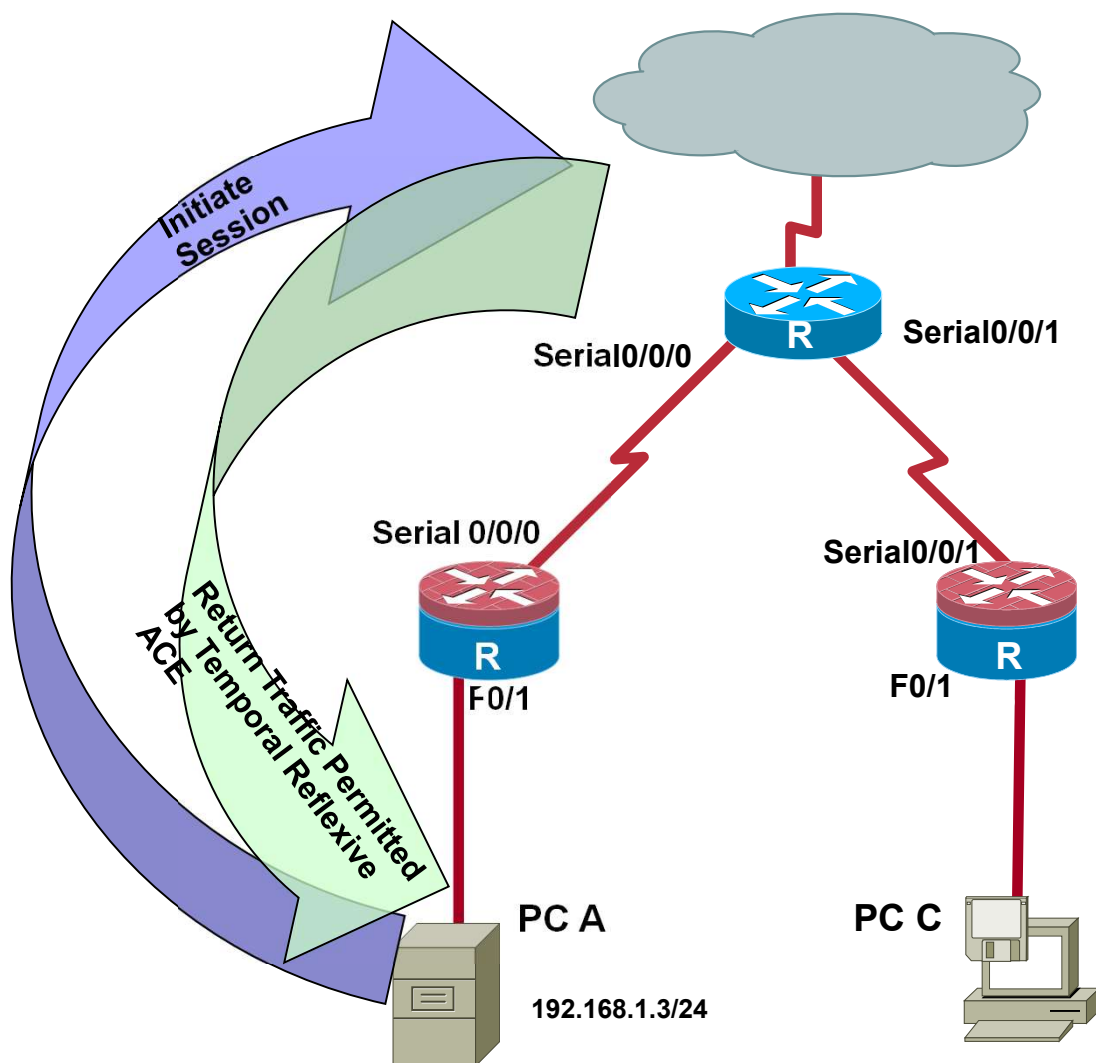
The established keyword:

- Forces a check by the routers to see if the ACK, FIN, PSH, RST, SYN or URG TCP control flags are set. If flag is set, the TCP traffic is allowed in.
- Does not implement a stateful firewall on a router
- Hackers can take advantage of the open hole
- Option does not apply to UDP or ICMP traffic

Example Using TCP Established

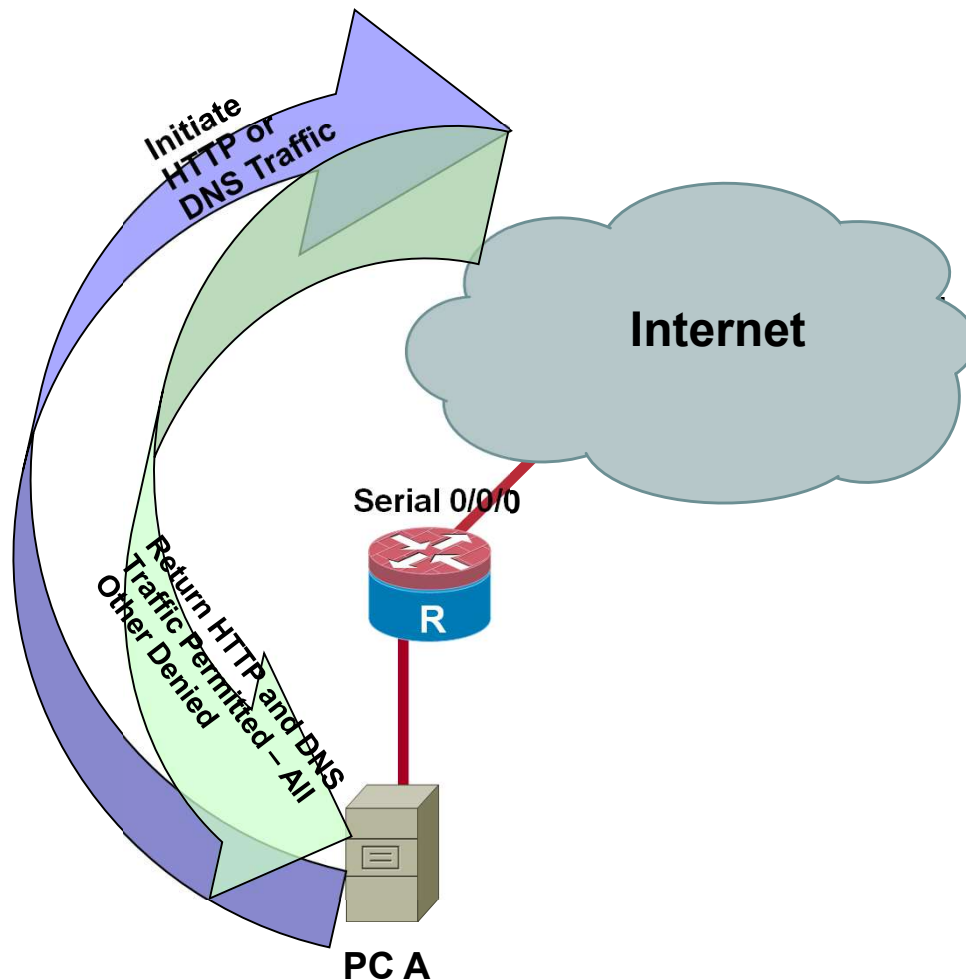


Reflexive ACLs



- Provide a truer form of session filtering
- Much harder to spoof
- Allow an administrator to perform actual session filtering for any type of IP traffic
- Work by using temporary access control entries (ACEs)

Configuring a Router to Use Reflexive ACLs



1. Create an internal ACL that looks for new outbound sessions and creates temporary reflexive ACEs
2. Create an external ACL that uses the reflexive ACLs to examine return traffic
3. Activate the named ACLs on the appropriate interfaces

Dynamic ACL Overview

- Available for IP traffic only
- Dependent on Telnet connectivity, authentication, and extended ACLs
- Security benefits include:
 - Use of a challenge mechanism to authenticate users
 - Simplified management in large internetworks
 - Reduction of the amount of router processing that is required for ACLs
 - Reduction of the opportunity for network break-ins by network hackers
 - Creation of dynamic user access through a firewall without compromising other configured security restrictions

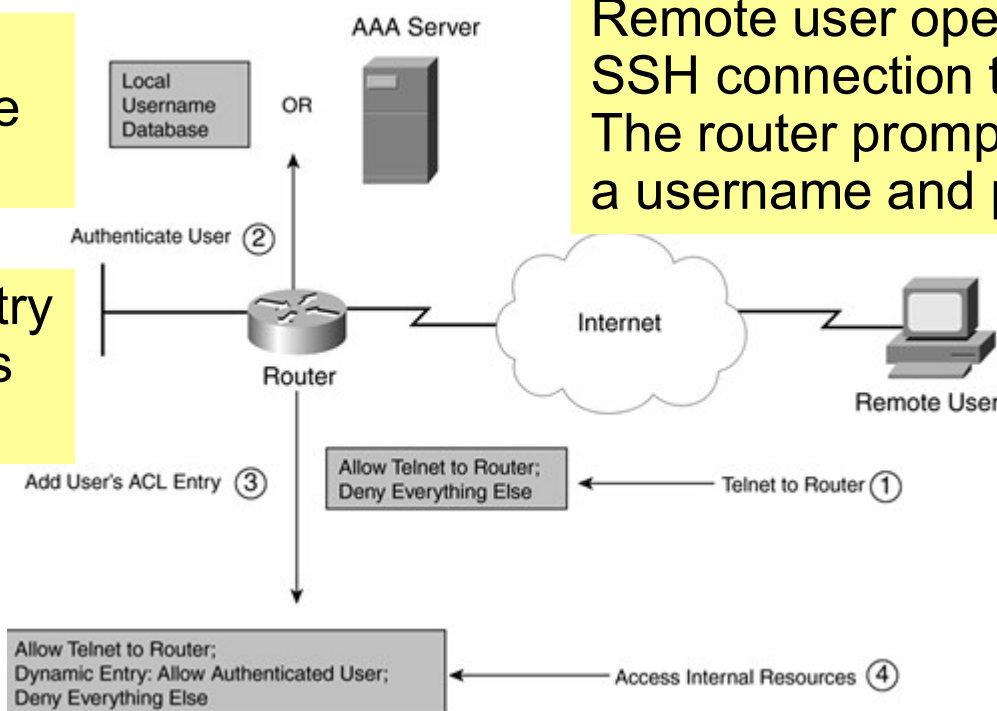


Implementing a Dynamic ACL

The router authenticates the connection

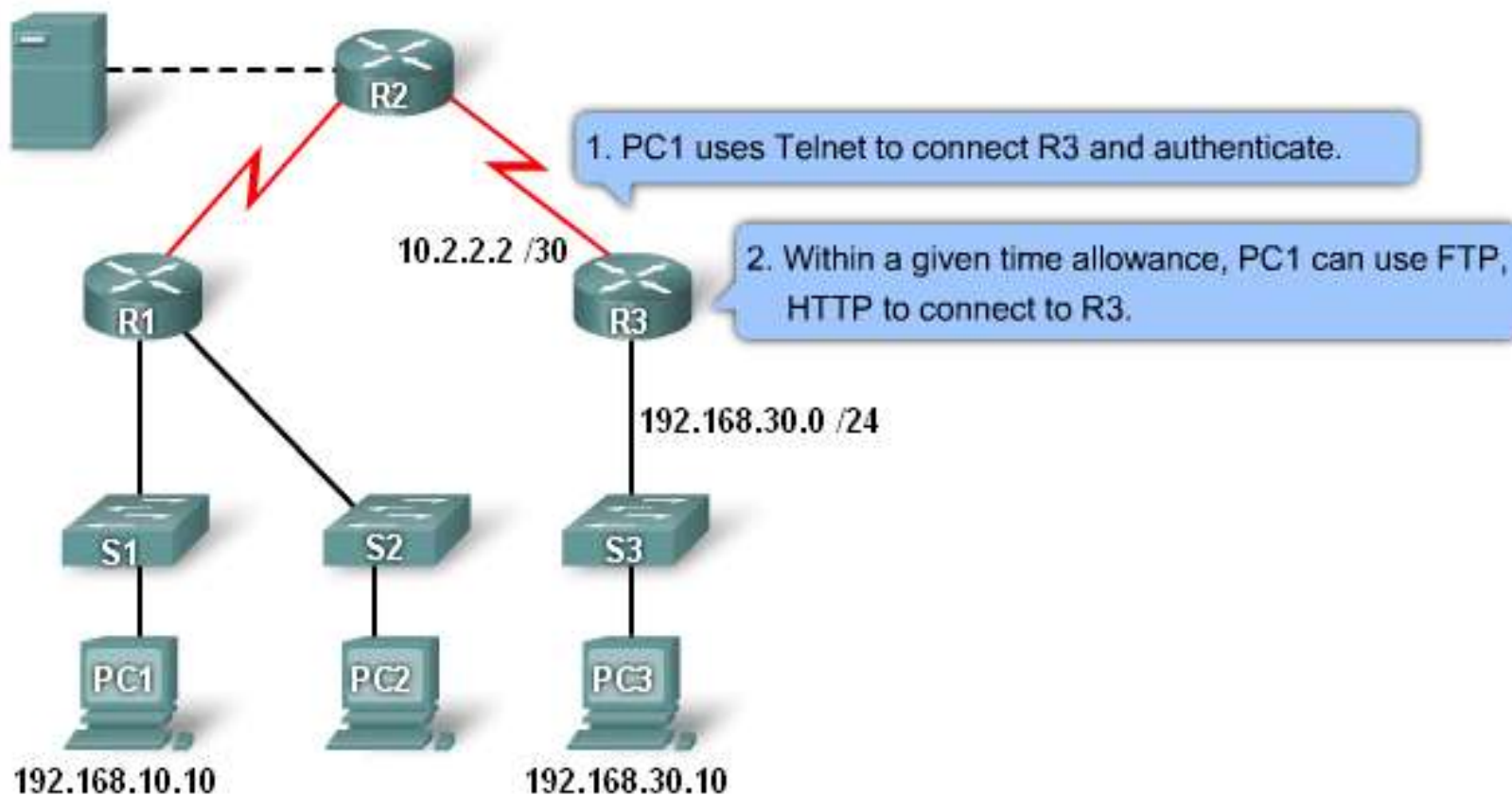
Dynamic ACL entry added that grants user access

Remote user opens a Telnet or SSH connection to the router. The router prompts the user for a username and password



User can access the internal resources

Setting up a Dynamic ACL



```
Router(config)# access-list ACL_# dynamic dynamic_ACL_name [timeout  
minutes] {deny | permit} IP_protocol source_IP_address src_wildcard_mask  
destination_IP_address dst_wildcard_mask [established] [log]
```

CLI Commands

Step 1

```
R3 (config) #username Student password 0 cisco
```

Step 2

```
R3 (config) # access-list 101 permit tcp any host 10.2.2.2  
eg telnet  
R3 (config) #access-list 101 dynamic testlist timeout 15  
permit ip 192.168.10.0 0.0.0.255 192.168.30.0 0.0.0.255
```

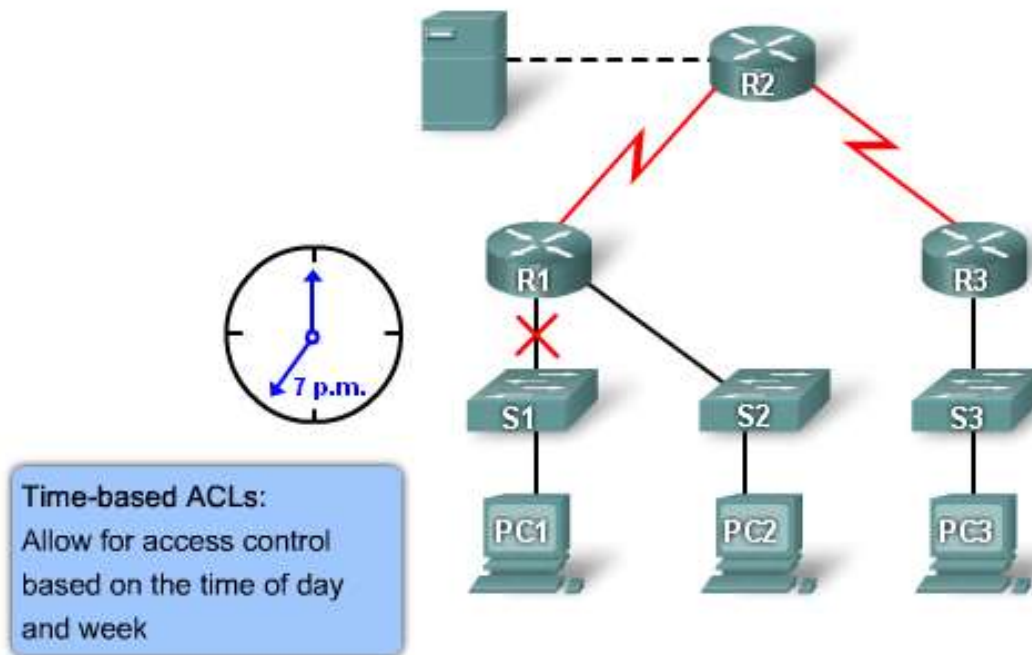
Step 3

```
R3 (config) #interface serial 0/0/1  
R3 (config-if) #ip access-group 101 in
```

Step 4

```
R3 (config) #line vty 0 4  
R3 (config-line) #login local  
R3 (config-line) # autocommand access-enable host timeout 5
```

Time-based ACLs



CLI Commands

Step 1

```
R1(config)#time-range EVERYOTHERDAY  
R1(config-time-range)#periodic Monday Wednesday Friday 8:00 to 17:00
```

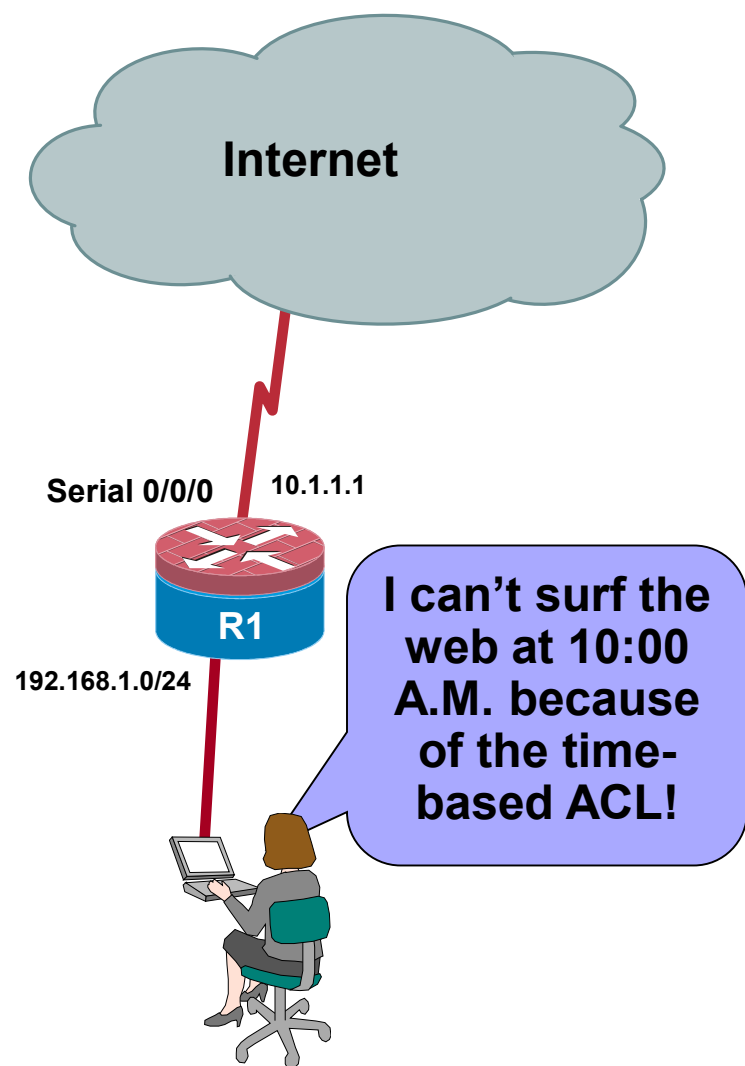
Step 2

```
R1(config)#access-list 101 permit tcp 192.168.10.0 0.0.0.255  
any eq telnet time-range EVERYOTHERDAY
```

Step 3

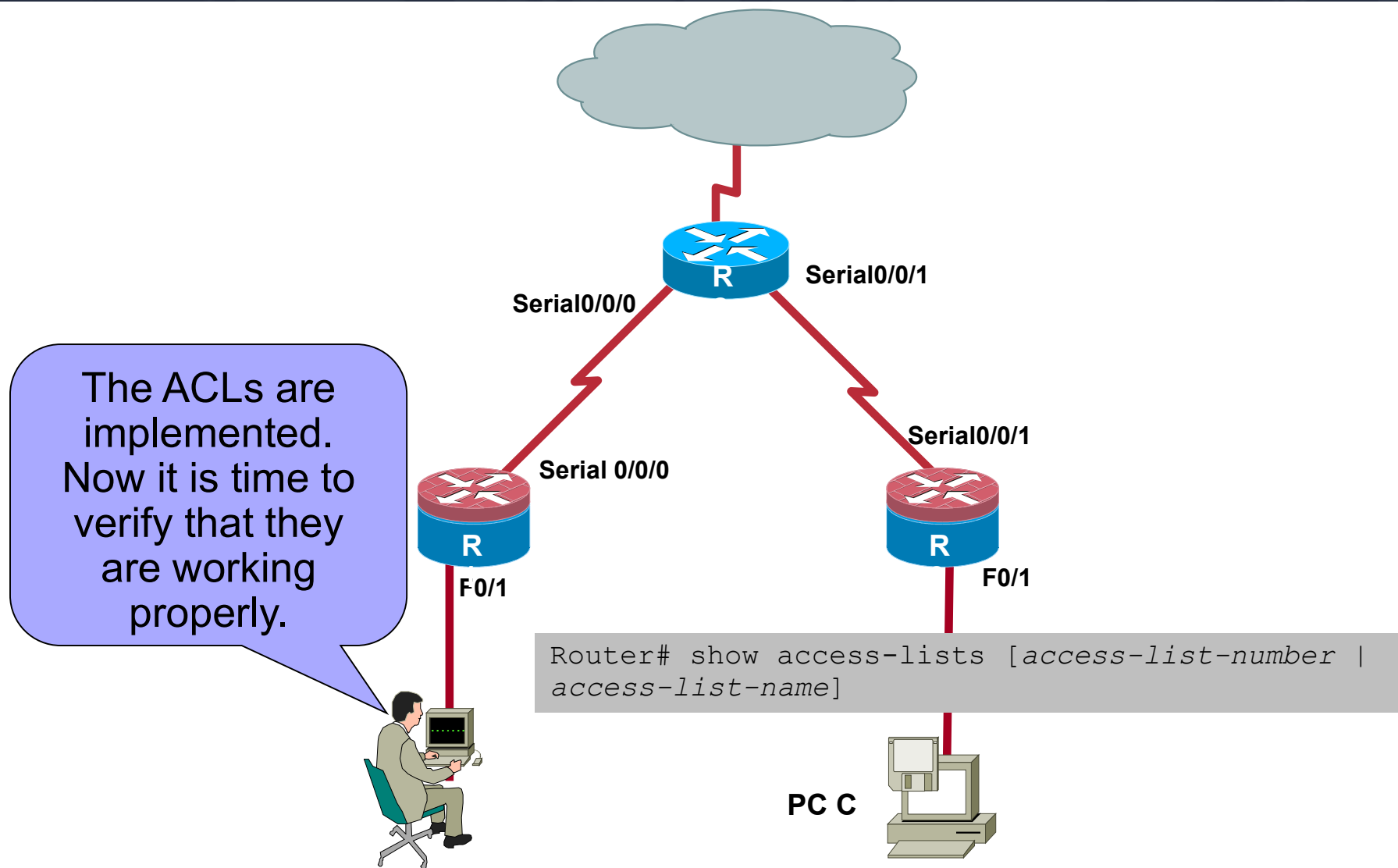
```
R1(config)#interface s0/0/0  
R1(config-if)#ip access-group 101 out
```

Example Configuration

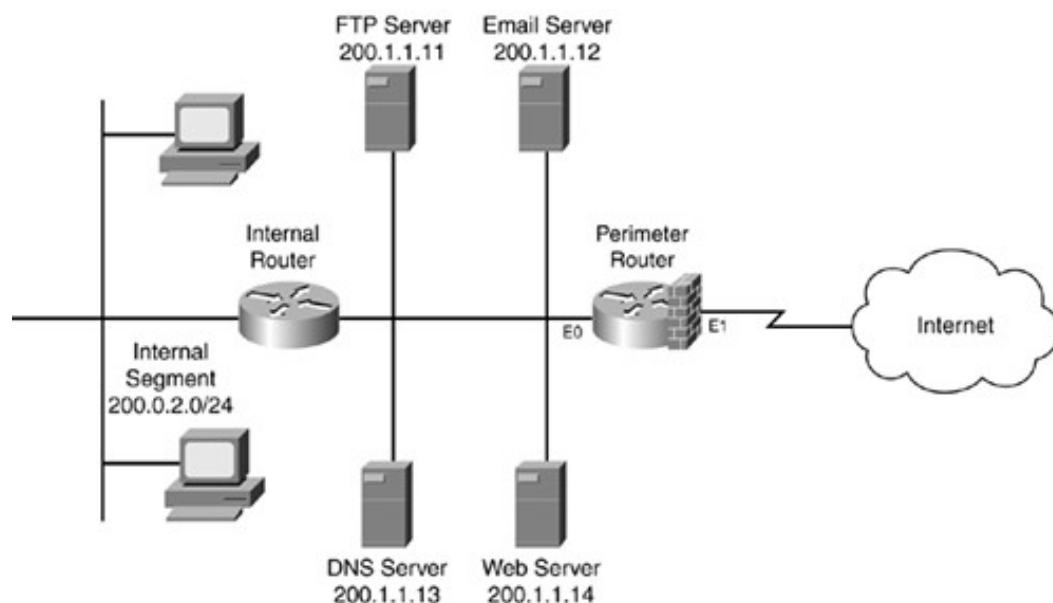


```
Perimeter(config)# time-range employee-time
Perimeter(config-time)# periodic weekdays 12:00 to 13:00
Perimeter(config-time)# periodic weekdays 17:00 to 19:00
Perimeter(config-time)# exit
Perimeter(config)# access-list 100 permit tcp any host
200.1.1.11 eq 25
Perimeter(config)# access-list 100 permit tcp any eq 25
host 200.1.1.11 established
Perimeter(config)# access-list 100 permit udp any host
200.1.1.12 eq 53
Perimeter(config)# access-list 100 permit udp any eq 53
host 200.1.1.12
Perimeter(config)# access-list 100 permit tcp any
200.1.1.0 0.0.0.255 established time-range employee-
time
Perimeter(config)# access-list 100 deny ip any any
Perimeter(config)# interface ethernet 1
Perimeter(config-if)# ip access-group 100 in
Perimeter(config-if)# exit
Perimeter(config)# access-list 101 permit tcp host
200.1.1.11 eq 25 any
Perimeter(config)# access-list 101 permit tcp host
200.1.1.11 any eq 25
Perimeter(config)# access-list 101 permit udp host
200.1.1.12 eq 53 any
Perimeter(config)# access-list 101 permit udp host
200.1.1.12 any eq 53
Perimeter(config)# access-list 101 permit tcp 200.1.1.0
0.0.0.255 any time-range employee-time
Perimeter(config)# access-list 100 deny ip any any
Perimeter(config)# interface ethernet 1
Perimeter(config-if)# ip access-group 101 out
```

Verifying ACL Configuration



Confirmation



```
Perimeter# show access-list 100
```

```
Extended IP access list 100
```

```
permit tcp any host 200.1.1.14 eq www (189 matches)  
permit udp any host 200.1.1.13 eq domain (32 matches)
```

```
permit tcp any host 200.1.1.12 eq smtp
```

```
permit tcp any eq smtp host 200.1.1.12 established
```

```
permit tcp any host 200.1.1.11 eq ftp
```

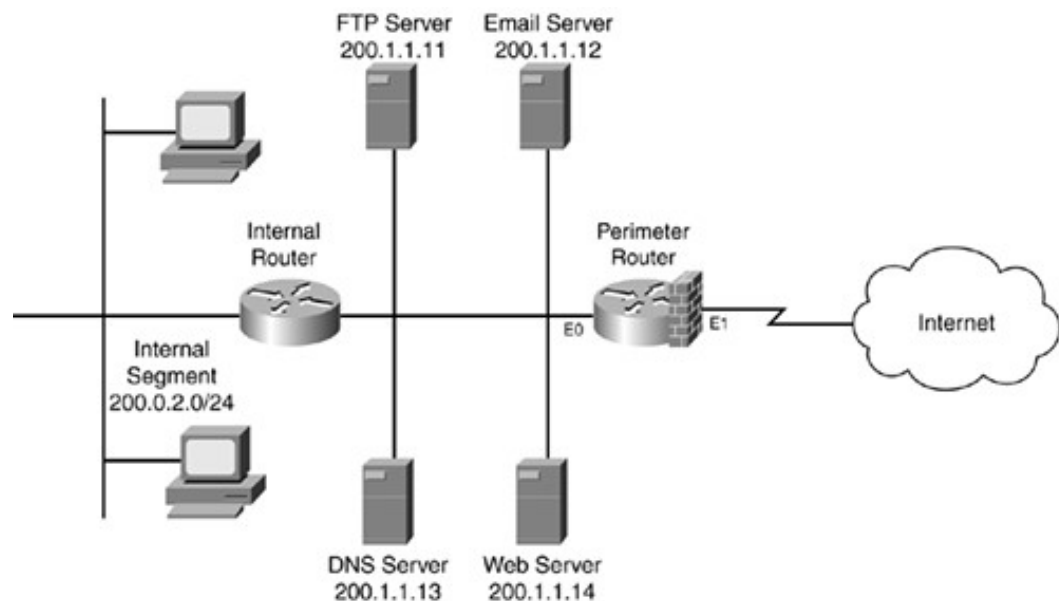
```
permit tcp any host 200.1.1.11 eq ftp-data
```

```
permit tcp any eq www 200.1.2.0 0.0.0.255 established
```

```
permit udp any eq domain 200.1.2.0 0.0.0.255
```

```
deny ip any any (1237 matches)
```

Troubleshooting



```
Perimeter# debug ip packet
```

```
IP packet debugging is on
```

```
IP: s=172.69.13.44 (Serial0/0), d=10.125.254.1 (Serial0/1), g=172.69.16.2, forward
IP: s=200.0.2.2 (Ethernet0), d=10.36.125.2 (Serial0/1), g=172.69.16.2, forward
IP: s=200.0.2.6 (Ethernet0), d=255.255.255.255, rcvd 2
IP: s=200.0.2.55 (Ethernet0), d=172.69.2.42 (Serial0/0), g=172.69.13.6, forward
IP: s=200.0.2.33 (Ethernet0), d=10.130.2.156 (Serial0/1), g=172.69.16.2, forward
IP: s=200.0.2.27 (Ethernet0), d=172.69.43.126 (Serial0/0), g=172.69.23.5, forward
IP: s=200.0.2.27 (Ethernet0), d=172.69.43.126 (Serial0/0), g=172.69.13.6, forward
IP: s=200.5.5.5 (Ethernet1), d=255.255.255.255, rcvd 2
```

```
IP: s=200.0.2.2 (Ethernet0), d=10.36.125.2 (Serial0/1), g=172.69.16.2, access denied
```

Attacks Mitigated



ACLs can be used to:

- Mitigate IP address spoofing—inbound
- Mitigate IP address spoofing—outbound
- Mitigate Denial of service (DoS) TCP synchronizes (SYN) attacks—blocking external attacks
- Mitigate DoS TCP SYN attacks—using TCP intercept
- Mitigate DoS smurf attacks
- Filter Internet Control Message Protocol (ICMP) messages—inbound
- Filter ICMP messages—outbound
- Filter traceroute

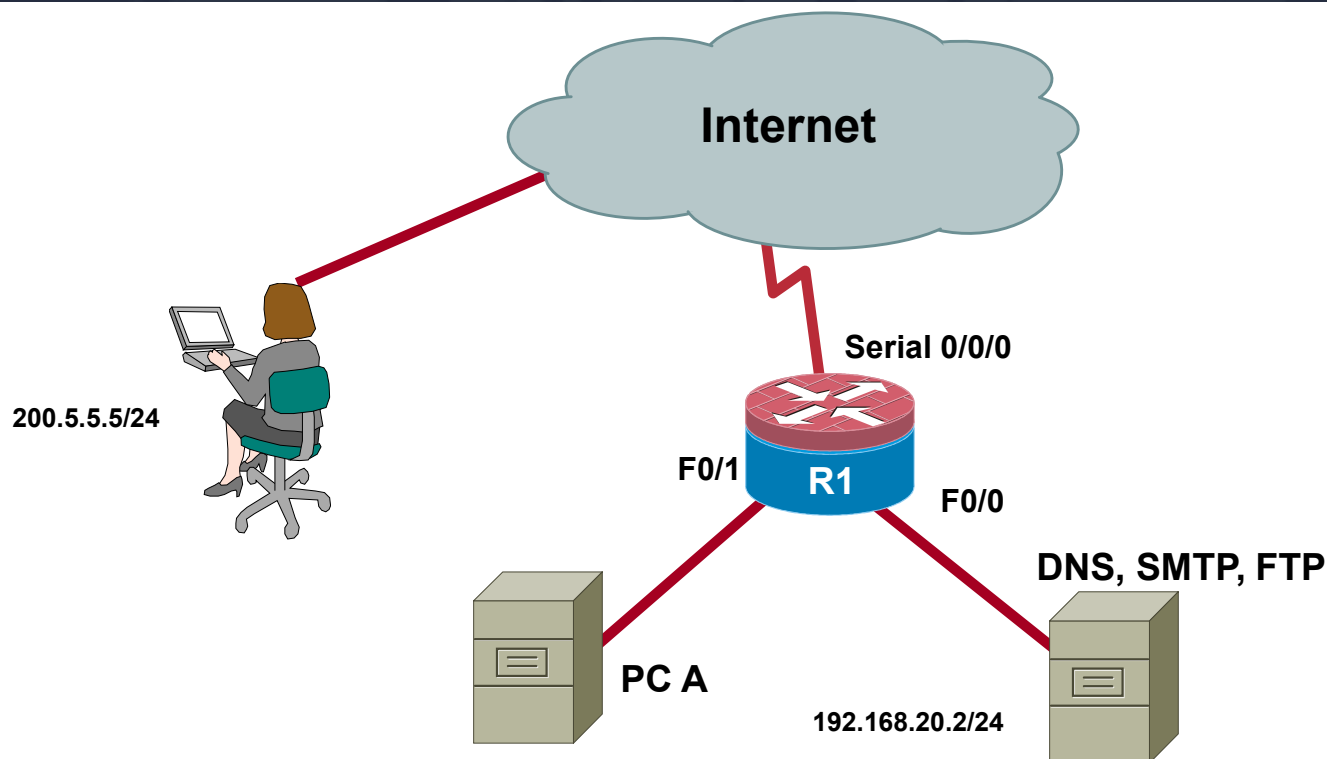
Inbound

```
R1(config)#access-list 150 deny ip 0.0.0.0 0.255.255.255 any
R1(config)#access-list 150 deny ip 10.0.0.0 0.255.255.255 any
R1(config)#access-list 150 deny ip 127.0.0.0 0.255.255.255 any
R1(config)#access-list 150 deny ip 172.16.0.0 0.15.255.255 any
R1(config)#access-list 150 deny ip 192.168.0.0 0.0.255.255 any
R1(config)#access-list 150 deny ip 224.0.0.0 15.255.255.255 any
R1(config)#access-list 150 deny ip host 255.255.255.255 any
```

Outbound

```
R1(config)#access-list 105 permit ip 192.168.1.0 0.0.0.255 any
```

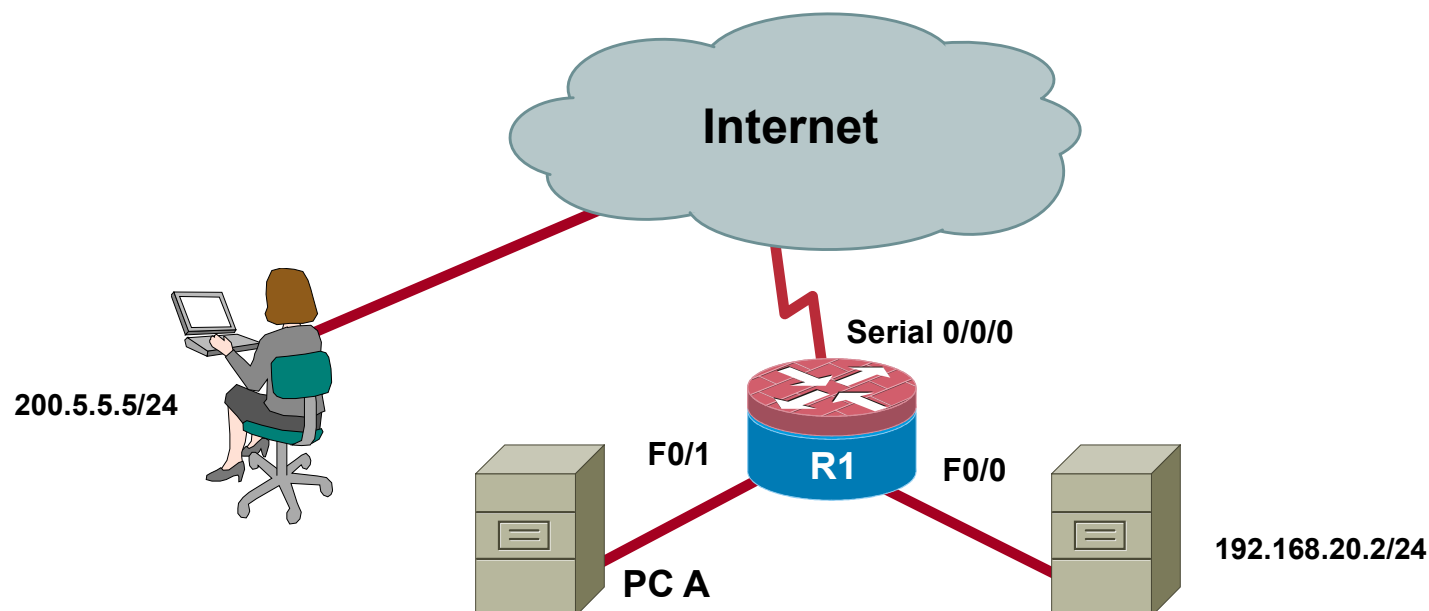
Allowing Common Services



```
R1(config)#access-list 122 permit udp any host 192.168.20.2 eq domain
R1(config)#access-list 122 permit tcp any host 192.168.20.2 eq smtp
R1(config)#access-list 122 permit tcp any host 192.168.20.2 eq ftp
```

```
R1(config)#access-list 180 permit tcp host 200.5.5.5 host 10.0.1.1 eq telnet
R1(config)#access-list 180 permit tcp host 200.5.5.5 host 10.0.1.1 eq 22
R1(config)#access-list 180 permit udp host 200.5.5.5 host 10.0.1.1 eq syslog
R1(config)#access-list 180 permit udp host 200.5.5.5 host 10.0.1.1 eq snmptrap
```

Controlling ICMP Messages



Inbound on S0/0/0

```
R1(config)#access-list 112 permit icmp any any echo-reply
R1(config)#access-list 112 permit icmp any any source-quench
R1(config)#access-list 112 permit icmp any any unreachable
R1(config)#access-list 112 deny icmp any any
```

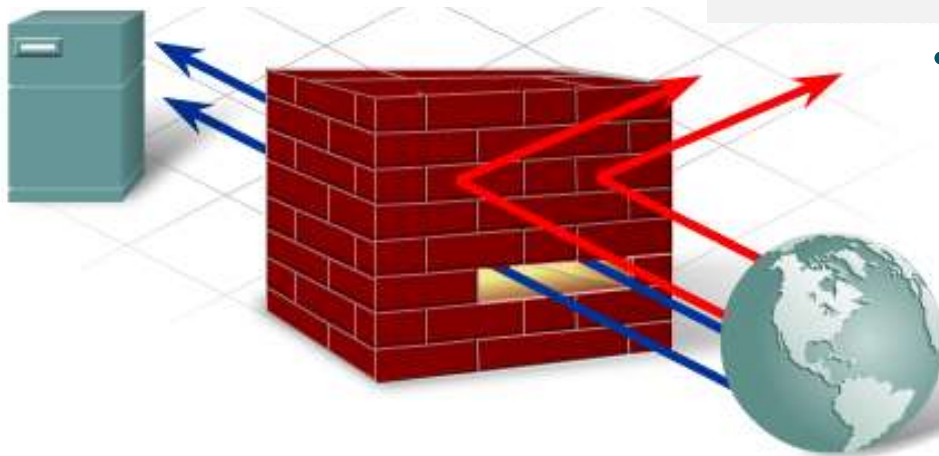
Outbound on S0/0/0

```
R1(config)#access-list 114 permit icmp 192.168.1.0 0.0.0.255 any echo
R1(config)#access-list 114 permit icmp 192.168.1.0 0.0.0.255 any parameter-problem
R1(config)#access-list 114 permit icmp 192.168.1.0 0.0.0.255 any packet-too-big
R1(config)#access-list 114 permit icmp 192.168.1.0 0.0.0.255 any source-quench
```

- A firewall is a system that enforces an access control policy between network
- Common properties of firewalls:
 - The firewall is resistant to attacks
 - The firewall is the only transit point between networks
 - The firewall enforces the access control policy

Benefits of Firewalls

- Prevents exposing sensitive hosts and applications to untrusted users
- Prevent the exploitation of protocol flaws by sanitizing the protocol flow
- Firewalls prevent malicious data from being sent to servers and clients.
- Properly configured firewalls make security policy enforcement simple, scalable, and robust.



- A firewall reduces the complexity of security management by offloading most of the network access control to a couple of points in the network.

Types of Filtering Firewalls



- Packet-filtering firewall—is typically a router that has) the capability to filter on some of the contents of packets (examines Layer 3 and sometimes Layer 4 information)
- Stateful firewall—keeps track of the state of a connection: whether the connection is in an initiation, data transfer, or termination state
- Application gateway firewall (proxy firewall) —filters information at Layers 3, 4, 5, and 7. Firewall control and filtering done in software.
- Address-translation firewall—expands the number of IP addresses available and hides network addressing design.

Types of Filtering Firewalls



- Host-based (server and personal) firewall—a PC or server with firewall software running on it.
- Transparent firewall—filters IP traffic between a pair of bridged interfaces.
- Hybrid firewalls—some combination of the above firewalls. For example, an application inspection firewall combines a stateful firewall with an application gateway firewall.

Packet-Filtering Firewall Advantages



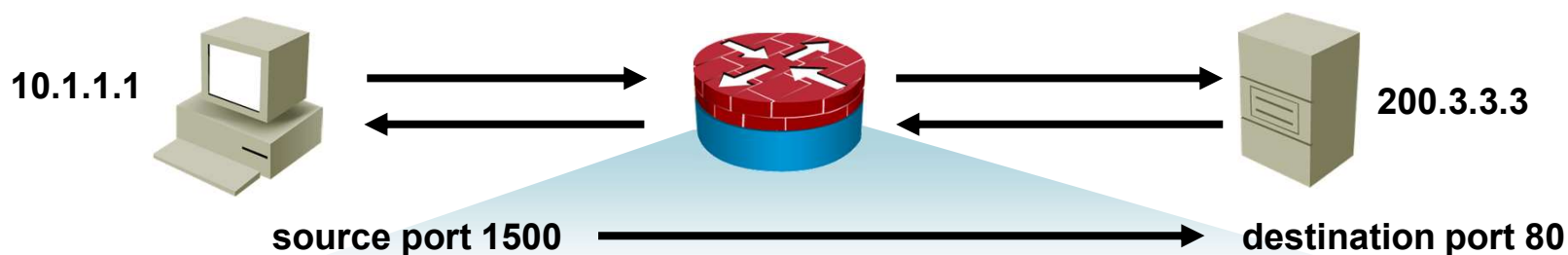
- Are based on simple permit or deny rule set
- Have a low impact on network performance
- Are easy to implement
- Are supported by most routers
- Afford an initial degree of security at a low network layer
- Perform 90% of what higher-end firewalls do, at a much lower cost

Packet-Filtering Firewall Disadvantages



- Packet filtering is susceptible to IP spoofing. Hackers send arbitrary packets that fit ACL criteria and pass through the filter.
- Packet filters do not filter fragmented packets well. Because fragmented IP packets carry the TCP header in the first fragment and packet filters filter on TCP header information, all fragments after the first fragment are passed unconditionally.
- Complex ACLs are difficult to implement and maintain correctly.
- Packet filters cannot dynamically filter certain services.
- Packet filters are stateless.

Stateful Firewall



Inside ACL (Outgoing Traffic)	Outside ACL (Incoming Traffic)
<pre>permit ip 10.0.0.0 0.0.0.255 any</pre>	<pre>Dynamic: permit tcp host 200.3.3.3 eq 80 host 10.1.1.1 eq 1500 permit tcp any host 10.1.1.2 eq 25 permit udp any host 10.1.1.2 eq 53 deny ip any any</pre>

Stateful Firewalls

Advantages/Disadvantages



Advantages	• Often used as a primary means of defense by filtering unwanted, unnecessary, or undesirable traffic. • Strengthens packet filtering by providing more stringent control over security than packet filtering • Improves performance over packet filters or proxy servers. • Defends against spoofing and DoS attacks • Allows for more log information than a packet filtering firewall
Disadvantages	• Cannot prevent application layer attacks because it does not examine the actual contents of the HTTP connection • Not all protocols are stateful, such UDP and ICMP • Some applications open multiple connections requiring a whole new range of ports opened to allow this second connection • Stateful firewalls do not support user authentication

Cisco Systems Firewall Solutions

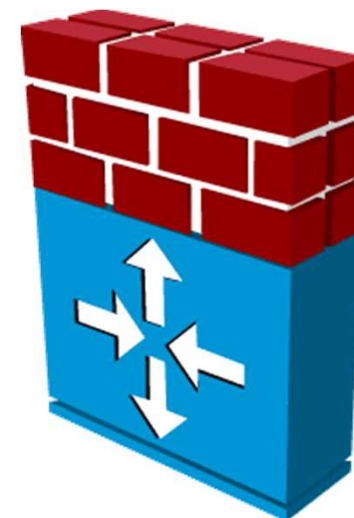


- **IOS Firewall**

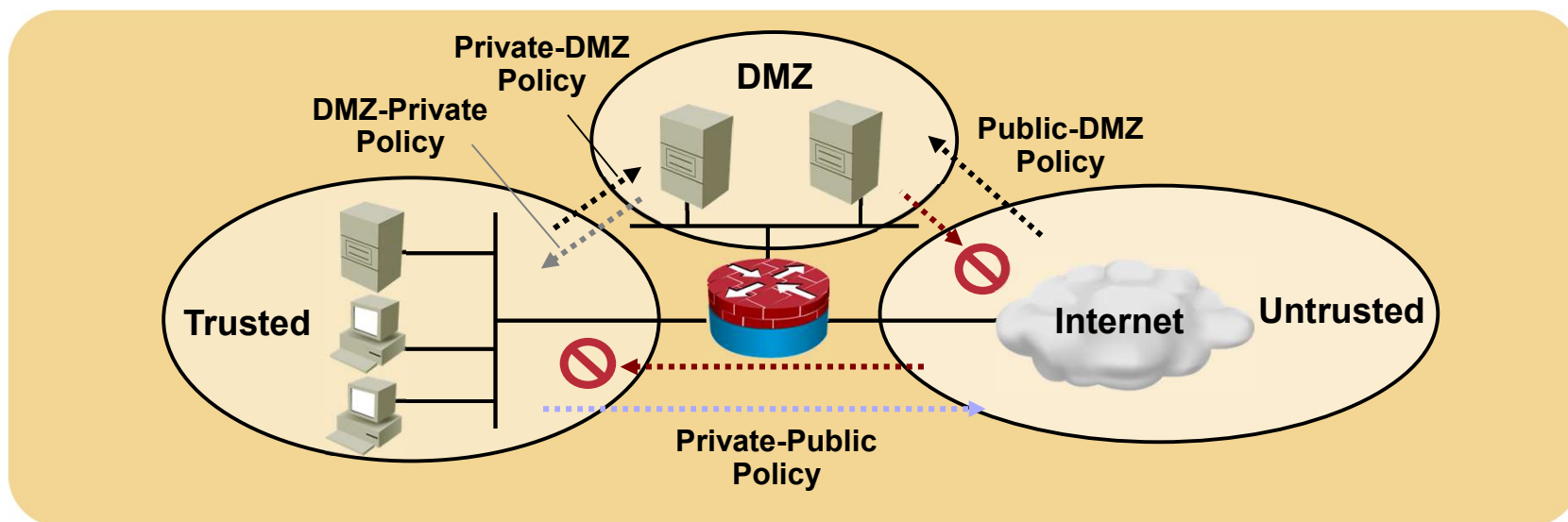
- Zone-based policy framework for intuitive management
- Instant messenger and peer-to-peer application filtering
- VoIP protocol firewalling
- Virtual routing and forwarding (VRF) firewalling
- Wireless integration
- Stateful failover
- Local URL whitelist and blacklist support
- Application inspection for web and e-mail traffic

- **PIX 500 Series**

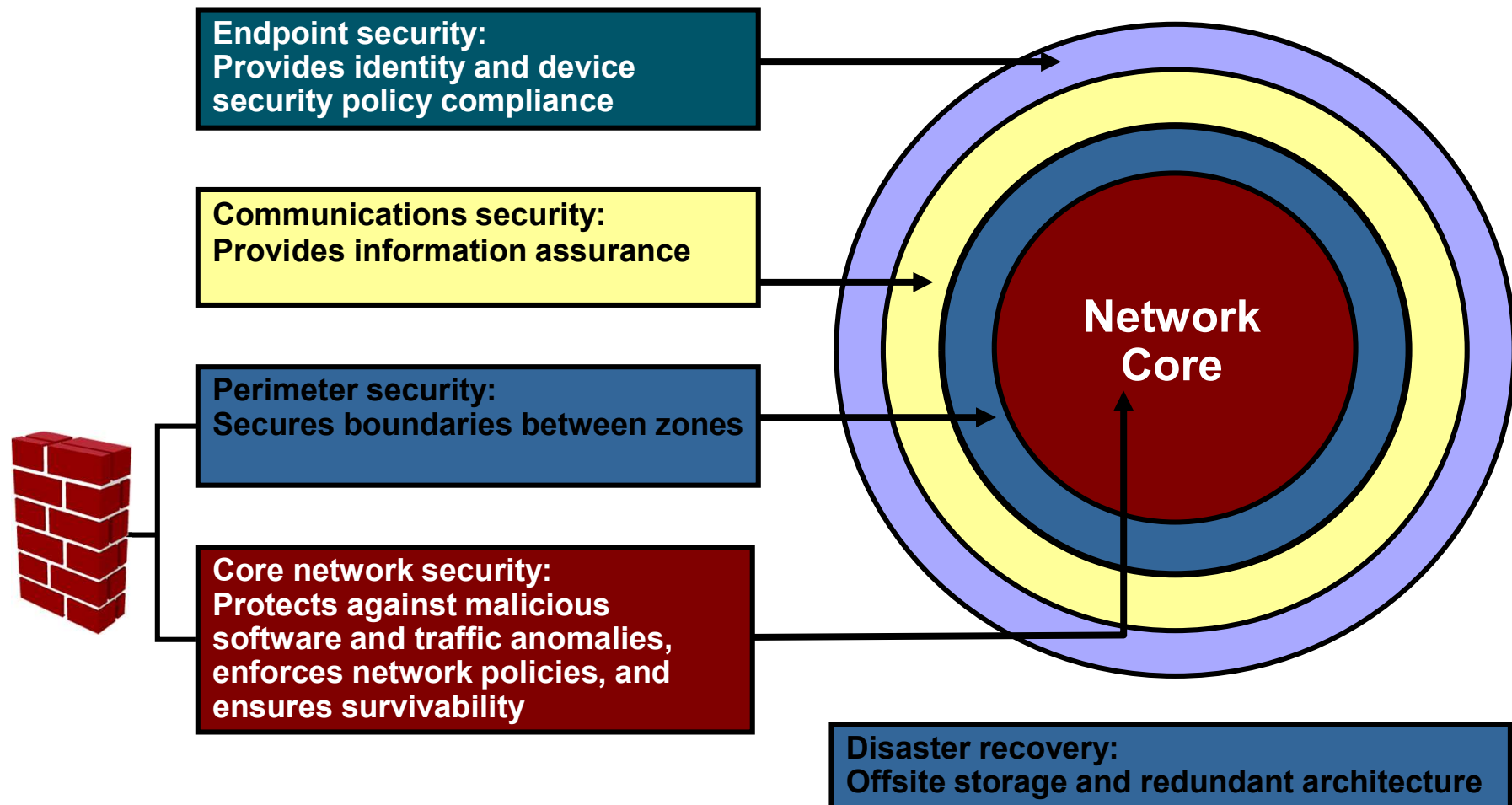
- **ASA 5500 Series**



Design with DMZ



Layered Defense Scenario

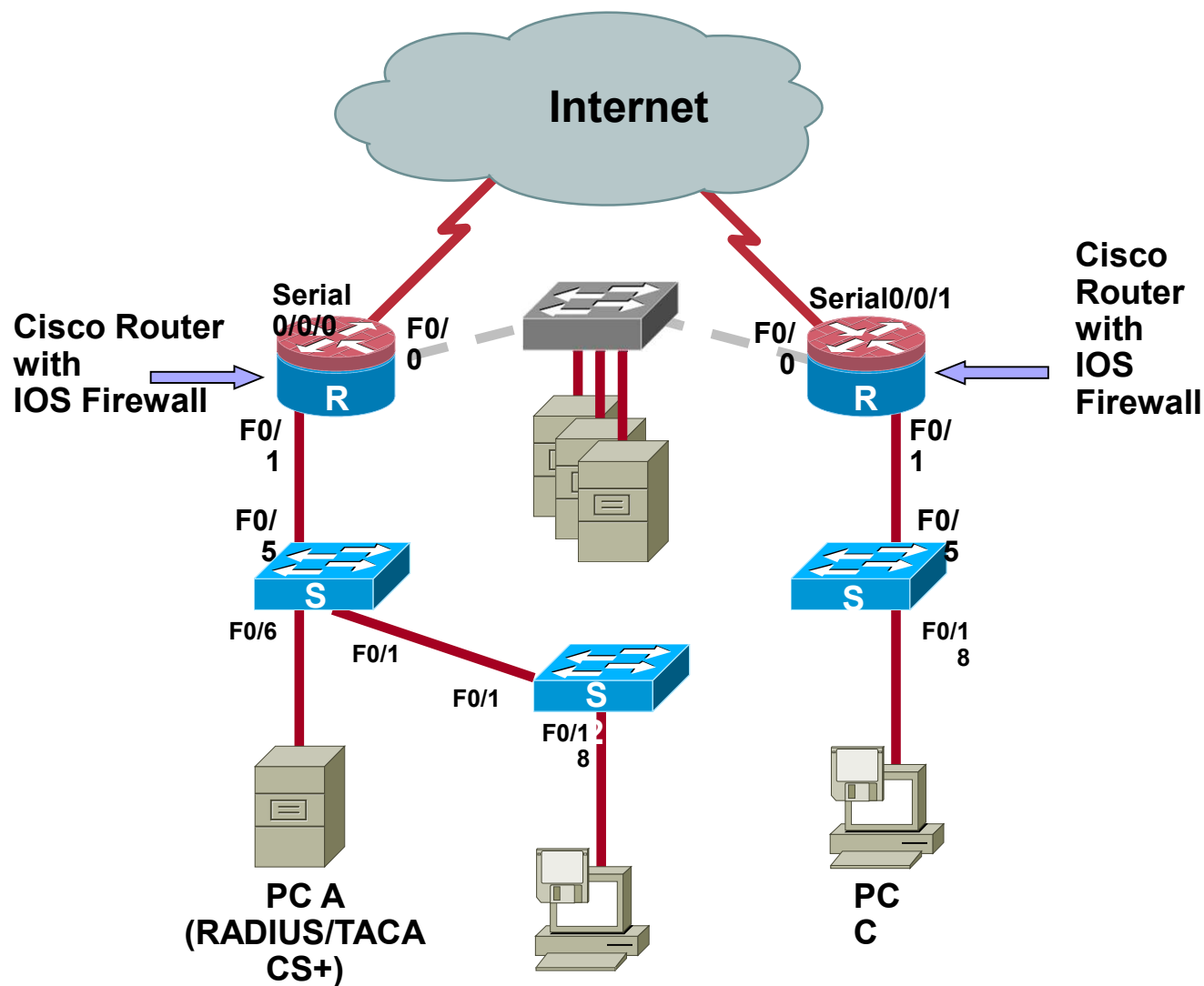


Firewall Best Practices

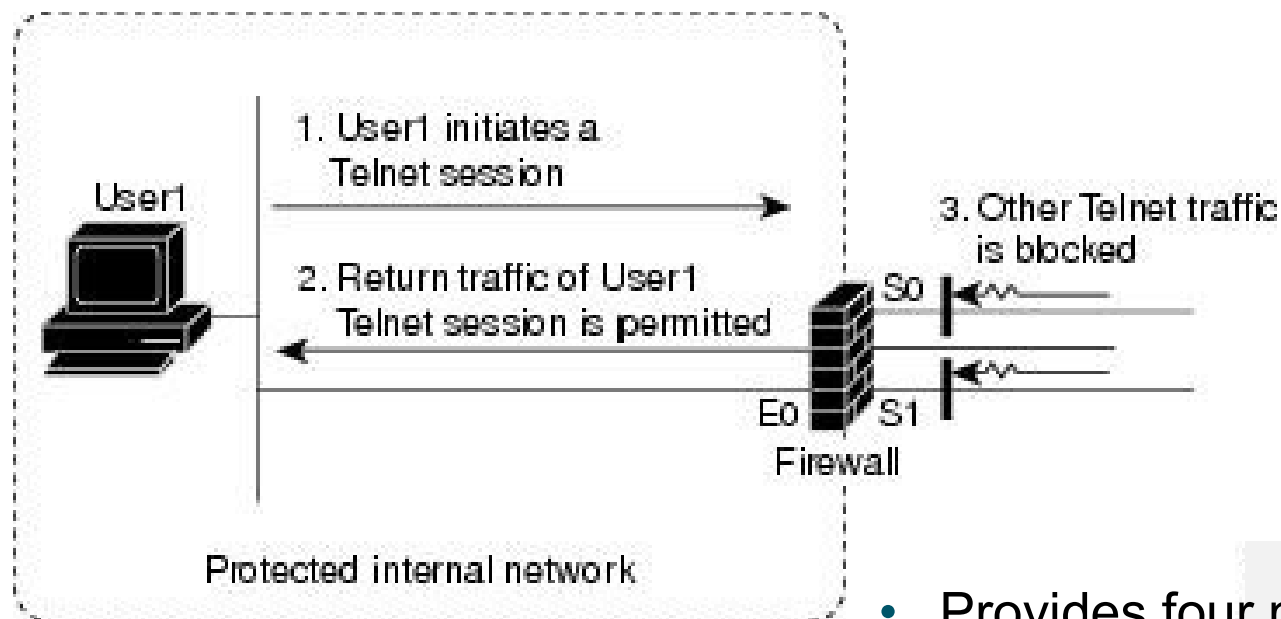


- Position firewalls at security boundaries.
- Firewalls are the primary security device. It is unwise to rely exclusively on a firewall for security.
- Deny all traffic by default. Permit only services that are needed.
- Ensure that physical access to the firewall is controlled.
- Regularly monitor firewall logs.
- Practice change management for firewall configuration changes.
- Remember that firewalls primarily protect from technical attacks originating from the outside.

Design Example



Introduction to CBAC



- Provides four main functions:
 - Traffic Filtering
 - Traffic Inspection
 - Intrusion Detection
 - Generation of Audits and Alerts
- Filters TCP and UDP packets based on application layer protocol session information
- Provides stateful application layer filtering

CBAC Capabilities



Monitors TCP Connection Setup

Examines TCP Sequence Numbers

Inspects DNS Queries and Replies

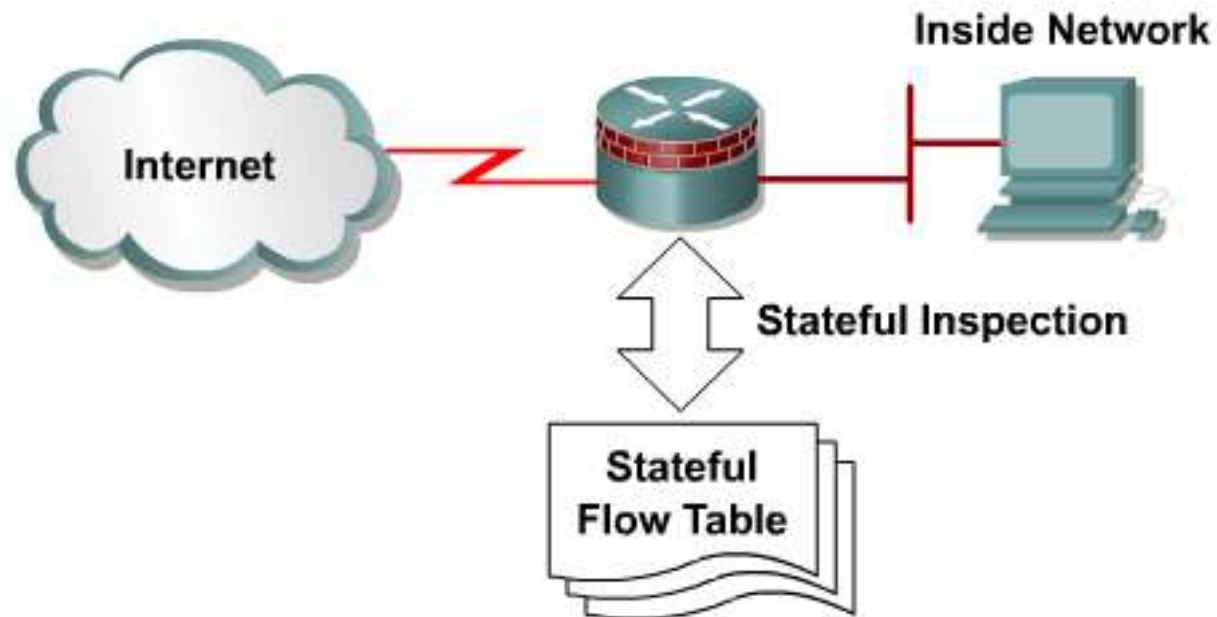
Inspects Common ICMP Message Types

**Supports Applications with Multiple Channels, such as
FTP and Multimedia**

Inspects Embedded Addresses

Inspects Application Layer Information

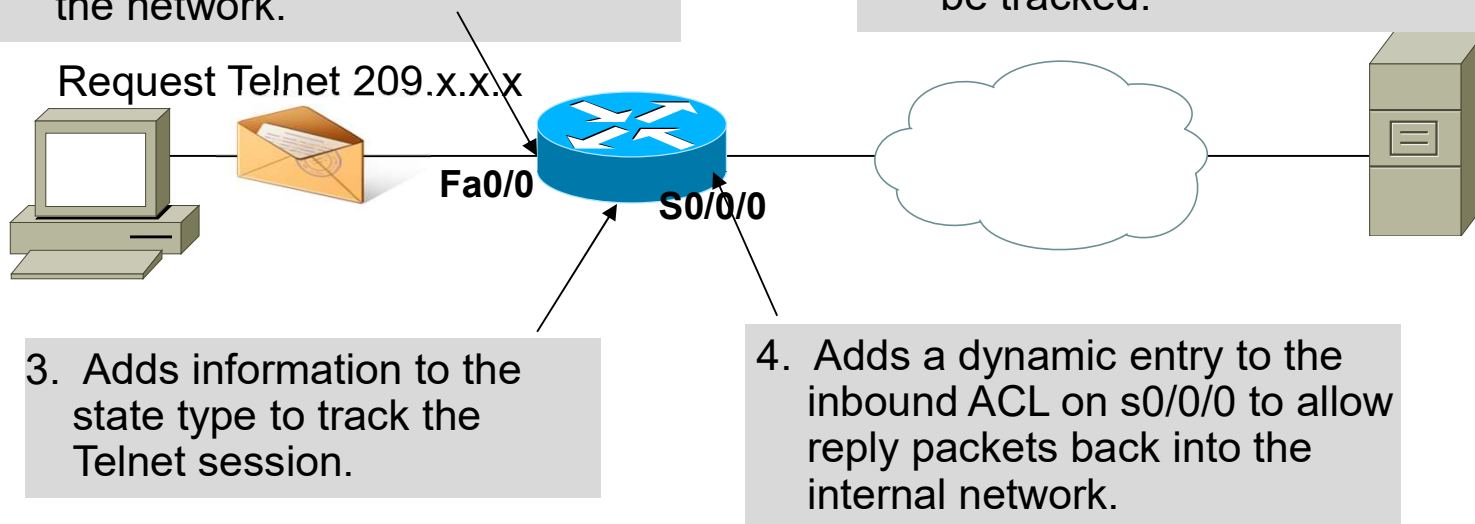
CBAC Overview



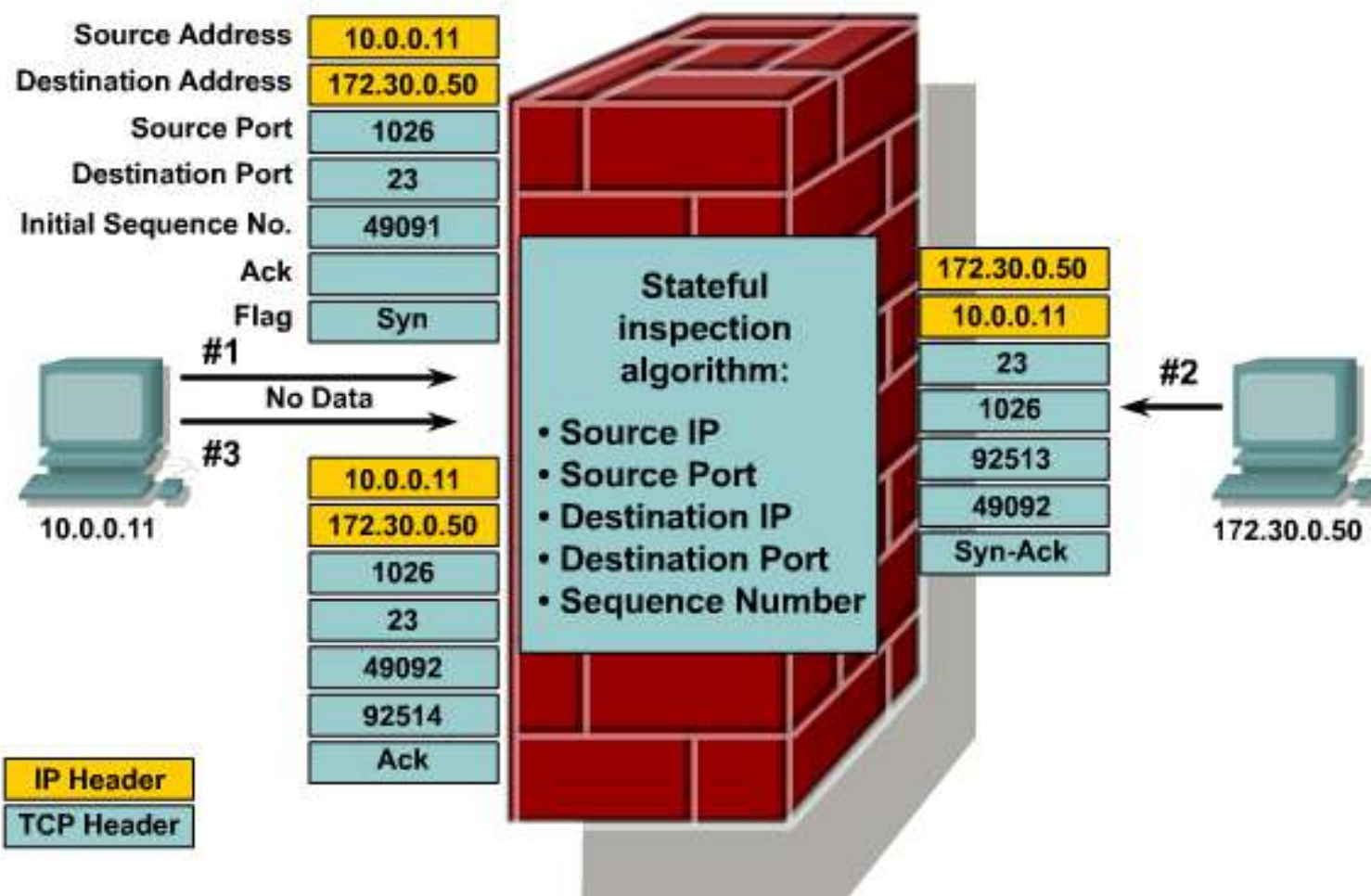
Step-by-Step

1. Examines the fa0/0 inbound ACL to determine if telnet requests are permitted to leave the network.

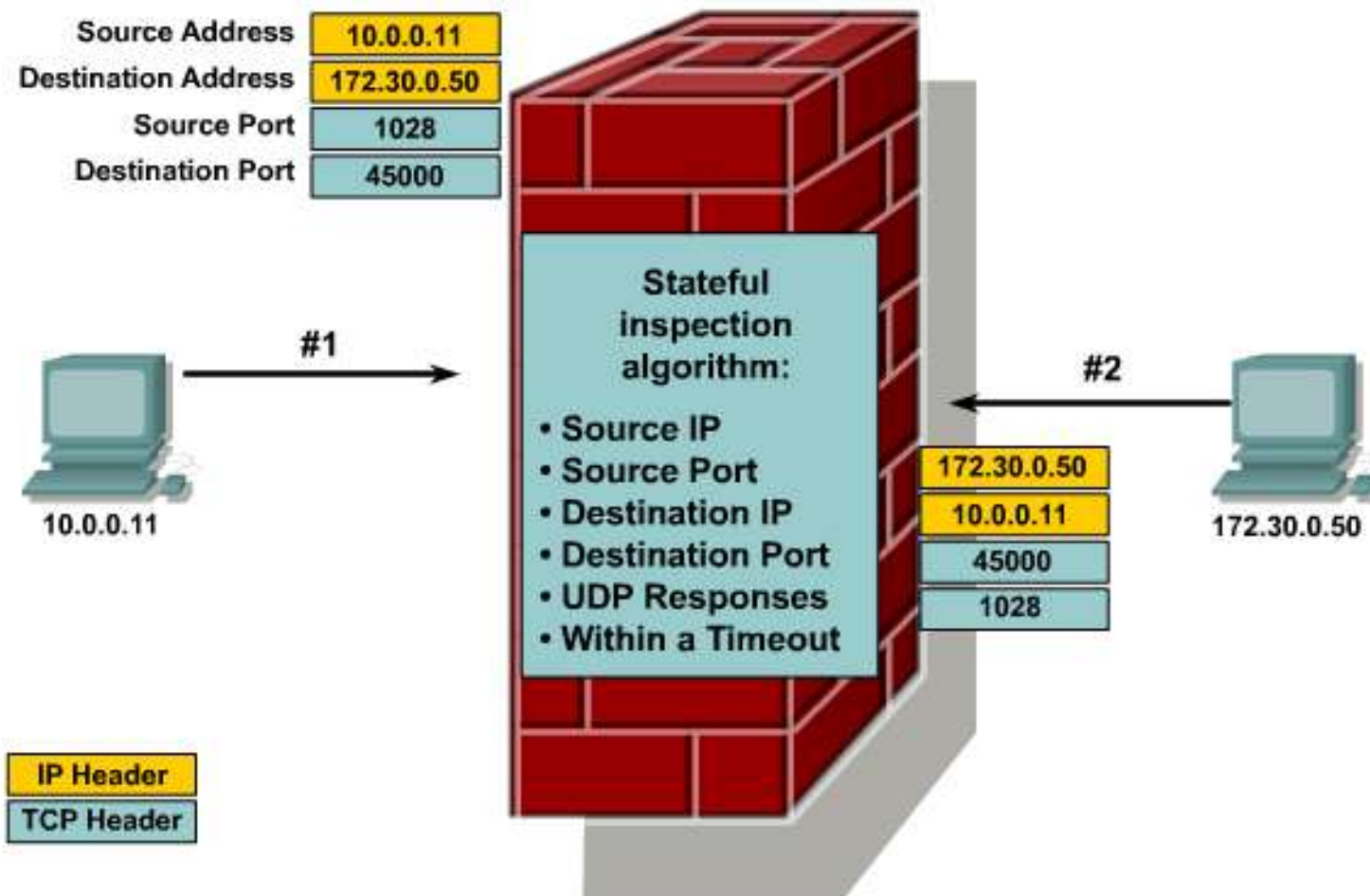
2. IOS compares packet type to inspection rules to determine if Telnet should be tracked.



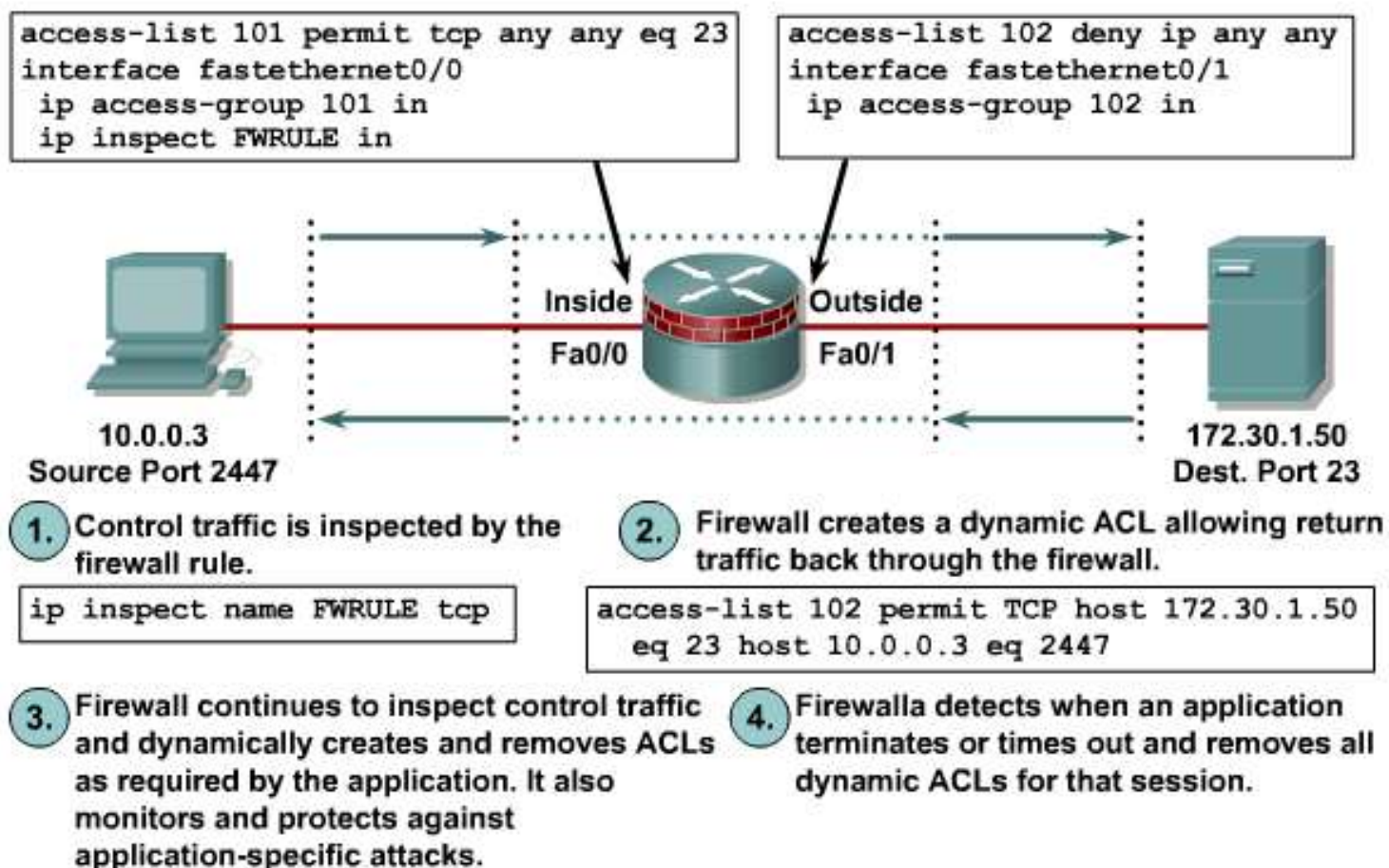
CBAC TCP Handling



CBAC UDP Handling



CBAC Example



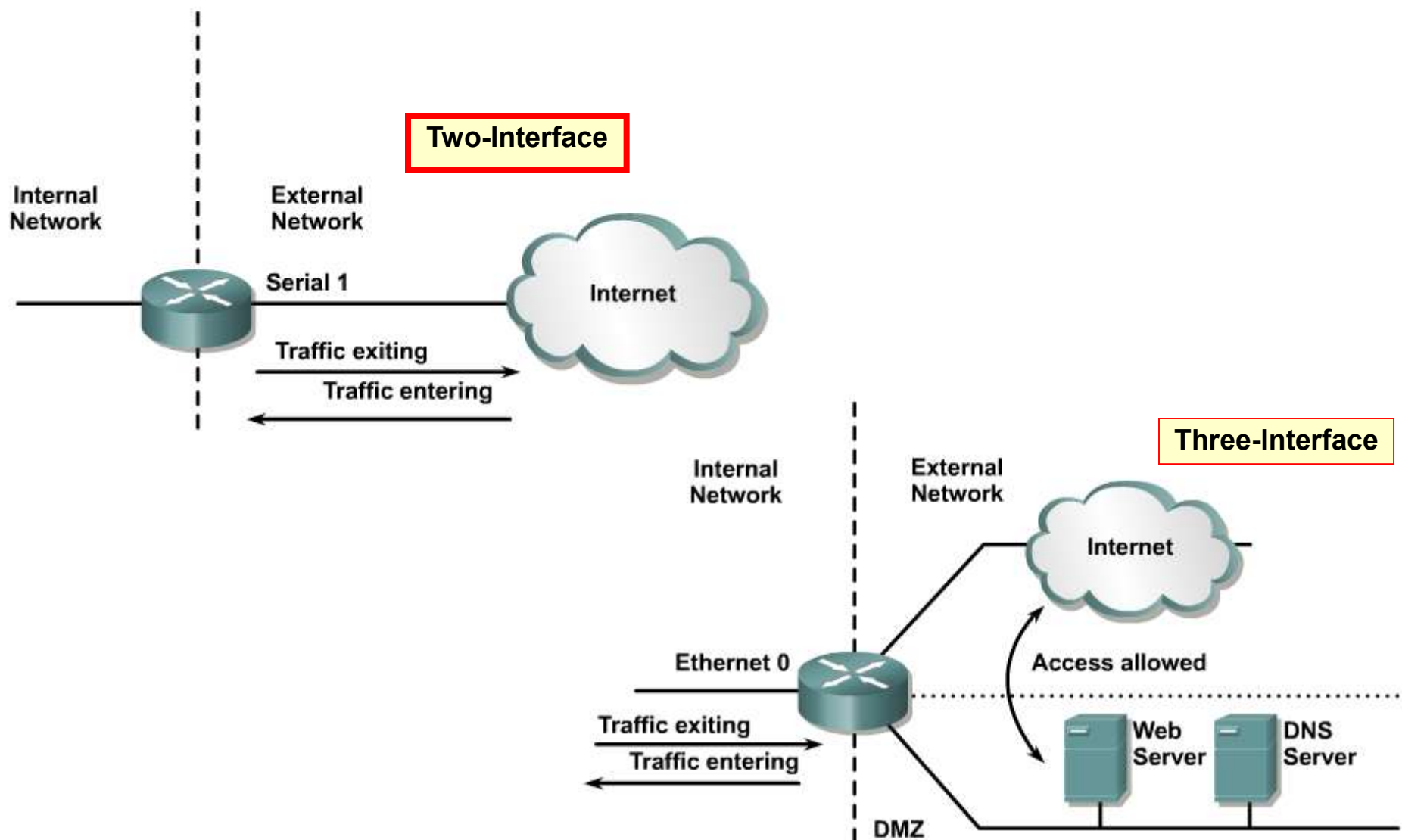
Configuration of CBAC



Four Steps to Configure

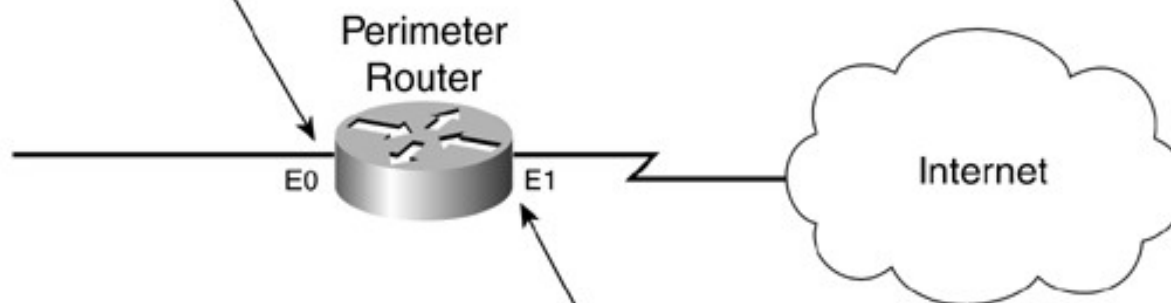
- Step 1: Pick an Interface
- Step 2: Configure IP ACLs at the Interface
- Step 3: Define Inspection Rules
- Step 4: Apply an Inspection Rule to an Interface

Step 1: Pick an Interface



Step 2: Configure IP ACLs at the Interface

```
interface ethernet0
  description inside
  ip access-group standard_or_extended_ACL in
  ip access-group extended_ACL out
```



```
interface ethernet1
  description outside
  ip access-group extended_ACL in
  ip access-group standard_or_extended_ACL out
```

Step 3: Define Inspection Rules

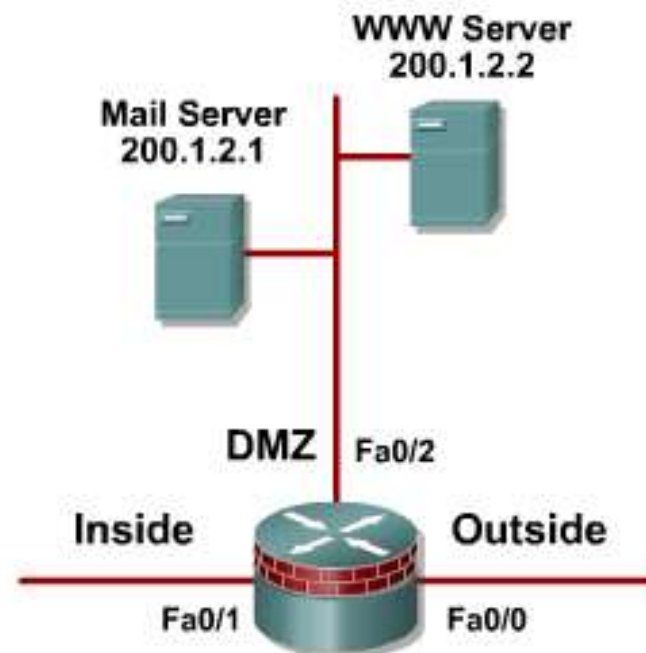
Router(config)#

```
ip inspect name inspection_name protocol [alert {on | off}] [audit-trail {on | off}] [timeout seconds]
```

Parameter	Description
<i>inspection-name</i>	Names the set of inspection rules. If you want to add a protocol to an existing set of rules, use the same inspection name for the rules.
<i>protocol</i>	The protocol to inspect.
alert {on off}	(Optional) For each inspected protocol, the generation of alert messages can be set to on or off. If no option is selected, alerts are generated based on the setting of the ip inspect alert-off command.
audit-trail {on off}	(Optional) For each inspected protocol, the audit-trail option can be set to on or off. If no option is selected, audit trail messages are generated based on the setting of the ip inspect audit-trail command.
timeout <i>seconds</i>	(Optional) Specify the number of seconds for a different idle timeout to override the global TCP or UDP idle timeouts for the specified protocol. This timeout overrides the global TCP and UDP timeouts but does not override the global Domain Name Service (DNS) timeout.

Step 4: Apply an Inspection Rule to an Interface

```
interface FastEthernet0/0
 ip inspect OUTSIDE in
 ip access-group OUTSIDEACL in
!
interface FastEthernet0/1
 ip inspect INSIDE in
 ip access-group INSIDEACL in
!
interface FastEthernet0/2
 ip access-group DMZACL in
!
ip inspect name INSIDE tcp
ip inspect name OUTSIDE tcp
!
ip access-list extended OUTSIDEACL
 permit tcp any host 200.1.2.1 eq 25
 permit tcp any host 200.1.2.2 eq 80
 permit icmp any any packet-too-big
 deny ip any any log
!
ip access-list extended INSIDEACL
 permit tcp any any eq 80
 permit icmp any any packet-too-big
 deny ip any any log
!
ip access-list extended DMZACL
 permit icmp any any packet-too-big
 deny ip any any log
```



Verification and Troubleshooting of CBAC



- Alerts and Audits
- `show ip inspect` Parameters
- `debug ip inspect` Parameters

Alerts and Audits

```
Router(config)#
```

```
no ip inspect alert-off
```

- Enables real-time alerts

*note: Alerts are enabled by default and automatically display on the console line of the router. If alerts have been disabled using the `ip inspect alert-off` command, the `no` form of that command, as seen above, is required to re-enable alerts.

```
Router(config)#
```

```
ip inspect audit-trail
```

- Enables the delivery of audit trail messages using syslog

```
Router(config)#logging on
```

```
Router(config)#logging host 10.0.0.3
```

```
Router(config)#ip inspect audit-trail
```

```
Router(config)#no ip inspect alert-off
```

show ip inspect Parameters

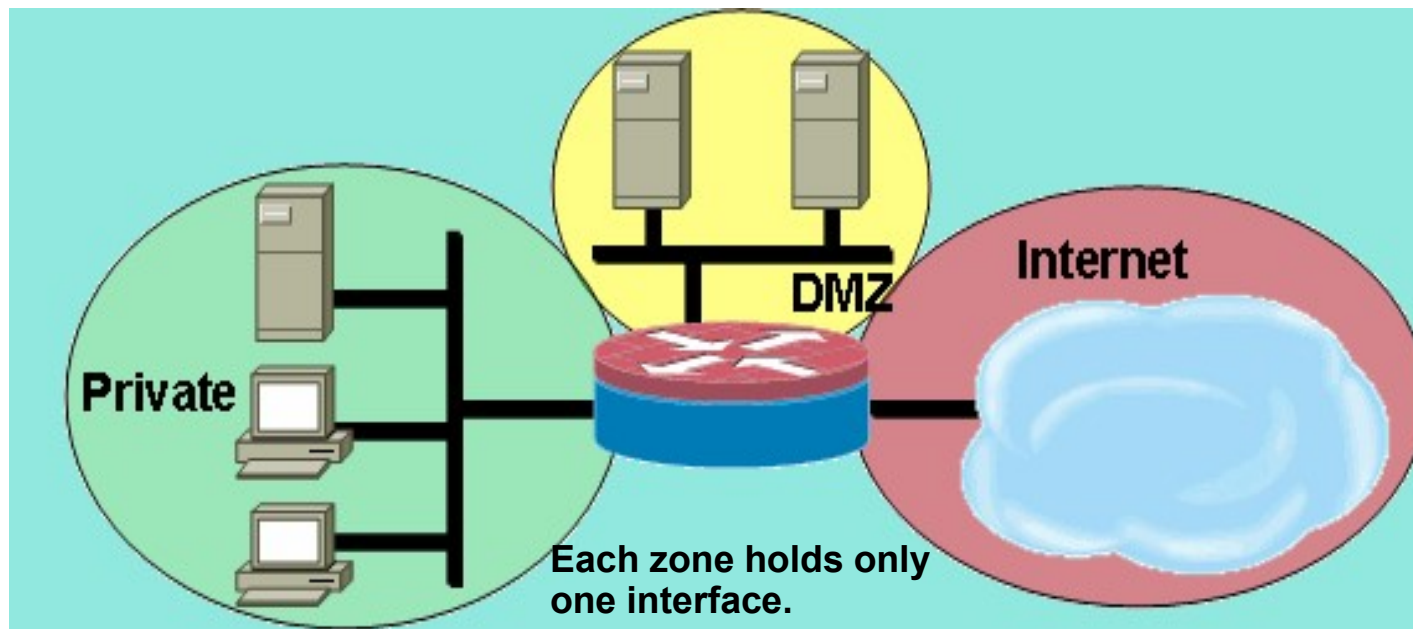
Parameter	Explanation
name <i>inspection_name</i>	Limits the output of the display to only the inspection rule set that you specified
config	Displays the complete CBAC inspection configuration on the router
interfaces	Displays the inspection rules activated on your router's interface(s)
session	Displays a summary of the connections in the CBAC state table
session [detail]	Displays all the details for connections in the CBAC state table
all	Displays all the information from the options listed in this table

debug ip inspect Parameters



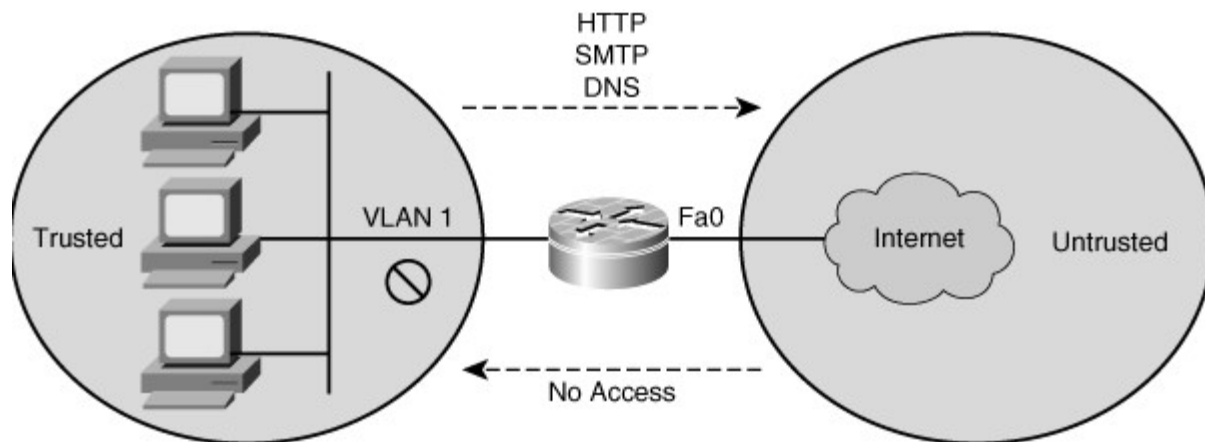
Parameter	Explanation
tcp	Displays TCP inspection events
udp	Displays UDP inspection events
icmp	Displays ICMP inspection events
<i>application_name</i>	Displays inspection events for the specified application, such as TFTP or SMTP
events	Displays CBAC events, including the processing of packets
object-creation	Displays information about an entry being added to the state table
object-deletion	Displays information about an entry being removed from the state table
function-trace	Displays information about the software functions that CBAC calls
timers	Displays information related to CBAC timers, such as information that the TCP or UDP idle timers are reached
detailed	Displays information about all the CBAC processes on the router

Topology Example



If an additional interface is added to the private zone, the hosts connected to the new interface in the private zone can pass traffic to all hosts on the existing interface in the same zone. Additionally, hosts connected to the new interface in the private zone must adhere to all existing “private” policies related to that zone when passing traffic to other zones.

Benefits



Two Zones

- The private zone must reach the Internet, with access to HTTP, SMTP, and DNS services.
- The Internet should not have any inbound access.

- Zone-based policy firewall is not dependent on ACLs
- The router security posture is now “block unless explicitly allowed”
- C3PL makes policies easy to read and troubleshoot
- One policy affects any given traffic, instead of needing multiple ACLs and inspection actions.

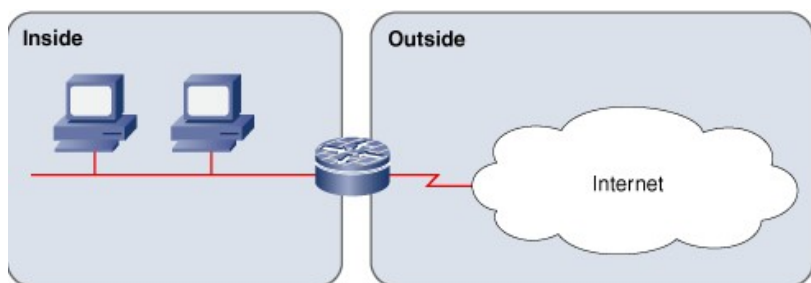
The Design Process



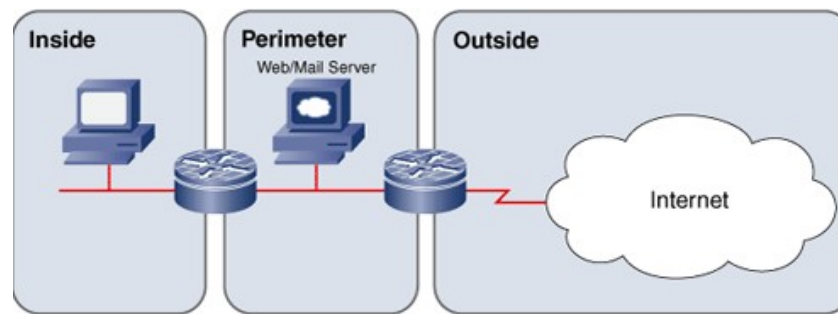
1. Internetworking infrastructure under consideration is split into well-documented separate zones with various security levels
2. For each pair of source-destination zones, the sessions that clients in source zones are allowed to open to servers in destination zones are defined. For traffic that is not based on the concept of sessions (for example, IPsec Encapsulating Security Payload [ESP]), the administrator must define unidirectional traffic flows from source to destination and vice versa.
3. The administrator must design the physical infrastructure.
4. For each firewall device in the design, the administrator must identify zone subsets connected to its interfaces and merge the traffic requirements for those zones, resulting in a device-specific interzone policy.

Common Designs

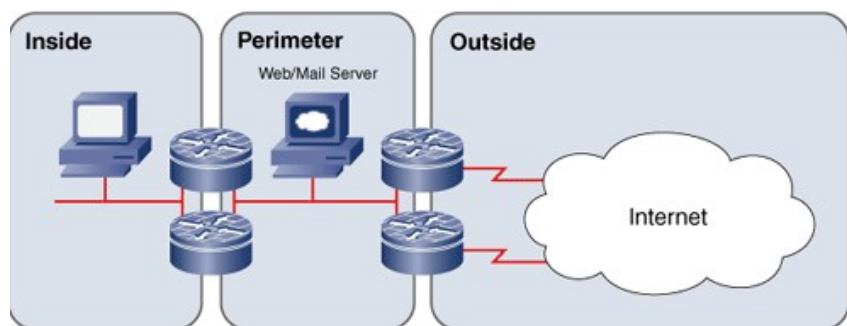
LAN-to-Internet



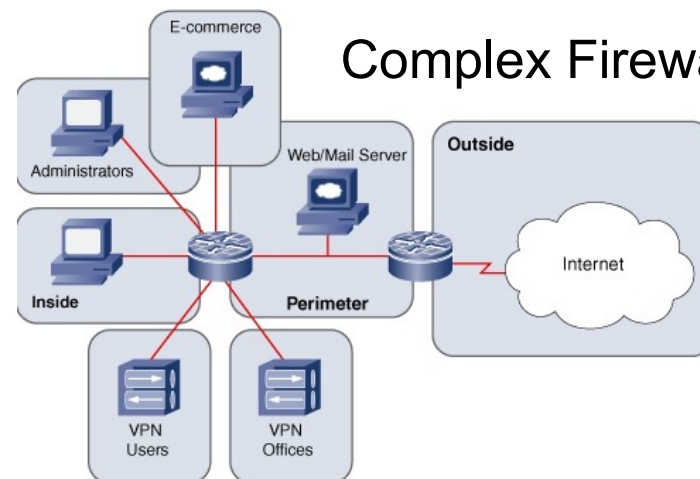
Public Servers



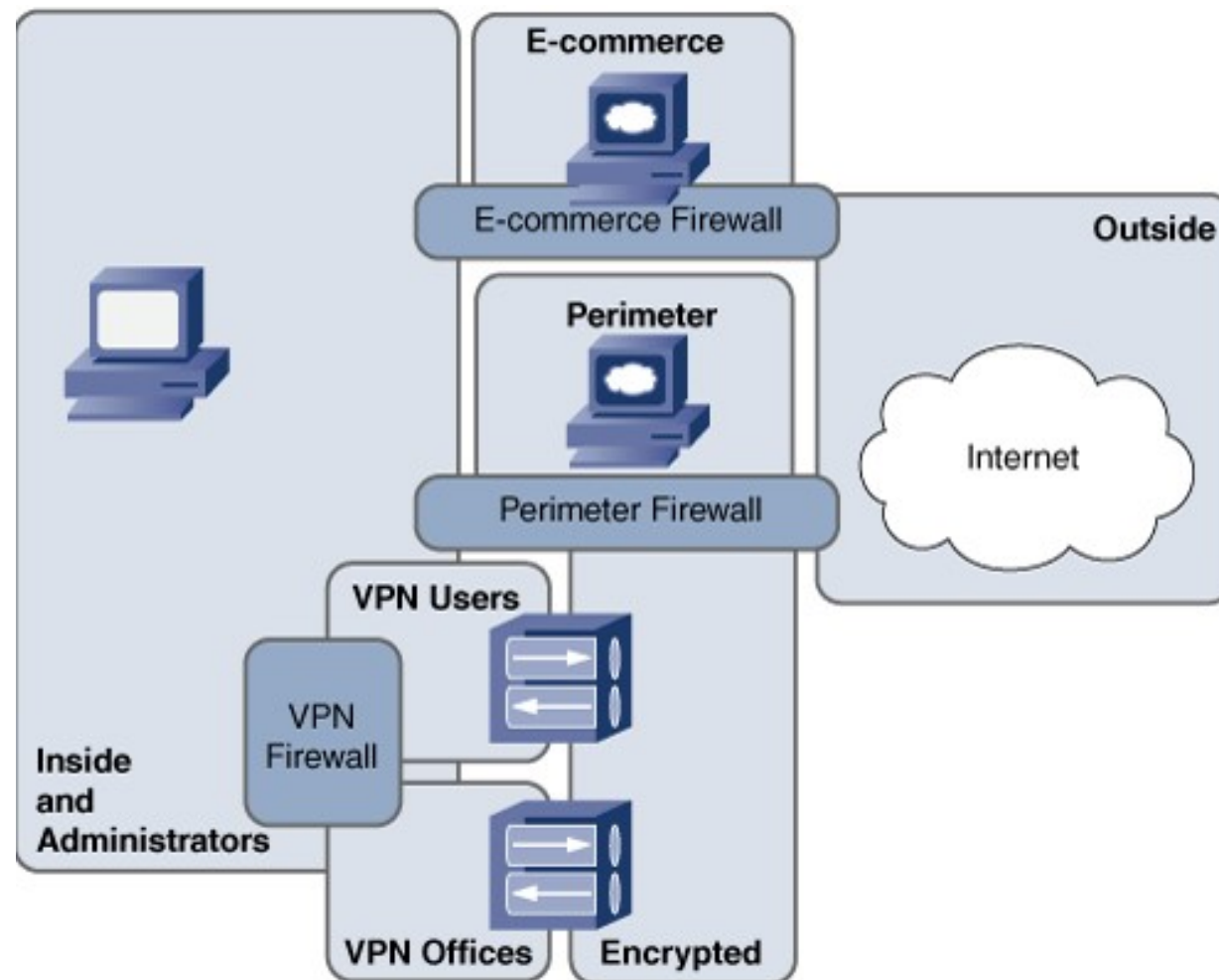
Redundant Firewalls



Complex Firewall



Zones Simplify Complex Firewall



Actions



Inspect – This action configures Cisco IOS stateful packet inspection



Drop – This action is analogous to deny in an ACL



Pass – This action is analogous to permit in an ACL

Rules for Application Traffic

Source interface member of zone?	Destination interface member of zone?	Zone-pair exists?	Policy exists?	RESULT
NO	NO	N/A	N/A	No impact of zoning/policy
YES (zone 1)	YES (zone 1)	N/A*	N/A	No policy lookup (PASS)
YES	NO	N/A	N/A	DROP
NO	YES	N/A	N/A	DROP
YES (zone 1)	YES (zone 2)	NO	N/A	DROP
YES (zone 1)	YES (zone 2)	YES	NO	DROP
YES (zone 1)	YES (zone 2)	YES	YES	policy actions

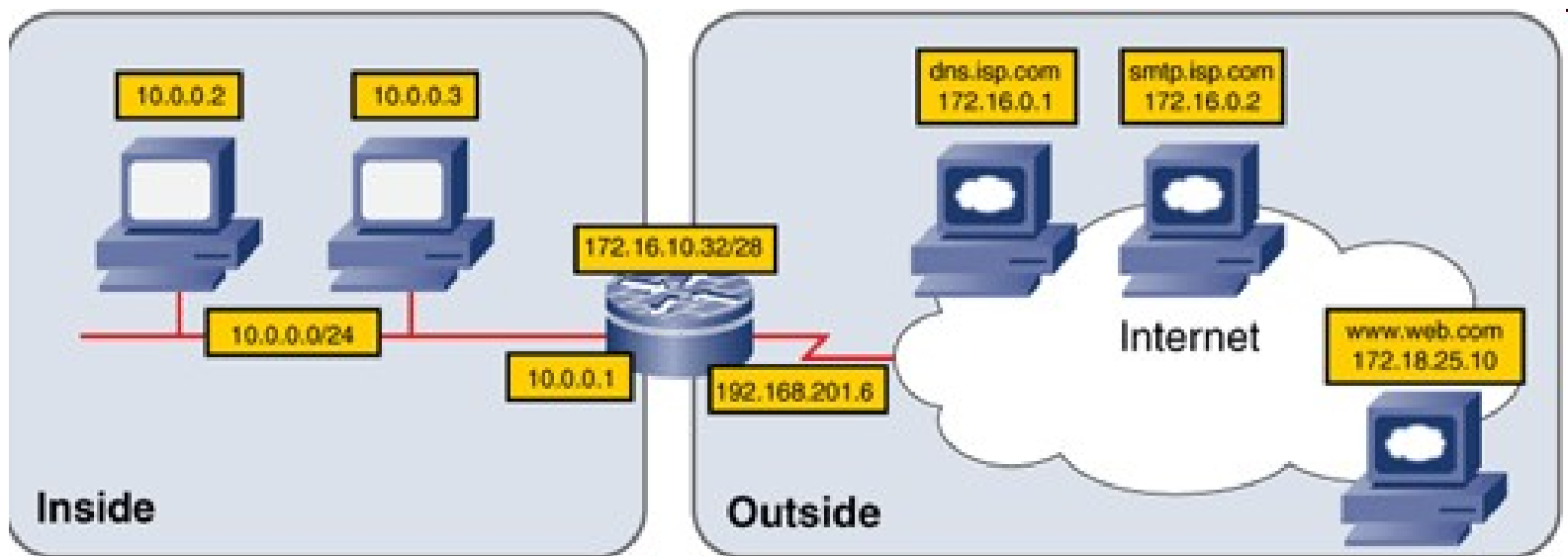
*zone-pair must have different zone as source and destination

Rules for Router Traffic

Source interface member of zone?	Destination interface member of zone?	Zone-pair exists?	Policy exists?	RESULT
ROUTER	YES	NO	-	PASS
ROUTER	YES	YES	NO	PASS
ROUTER	YES	YES	YES	policy actions
YES	ROUTER	NO	-	PASS
YES	ROUTER	YES	NO	PASS
YES	ROUTER	YES	YES	policy actions

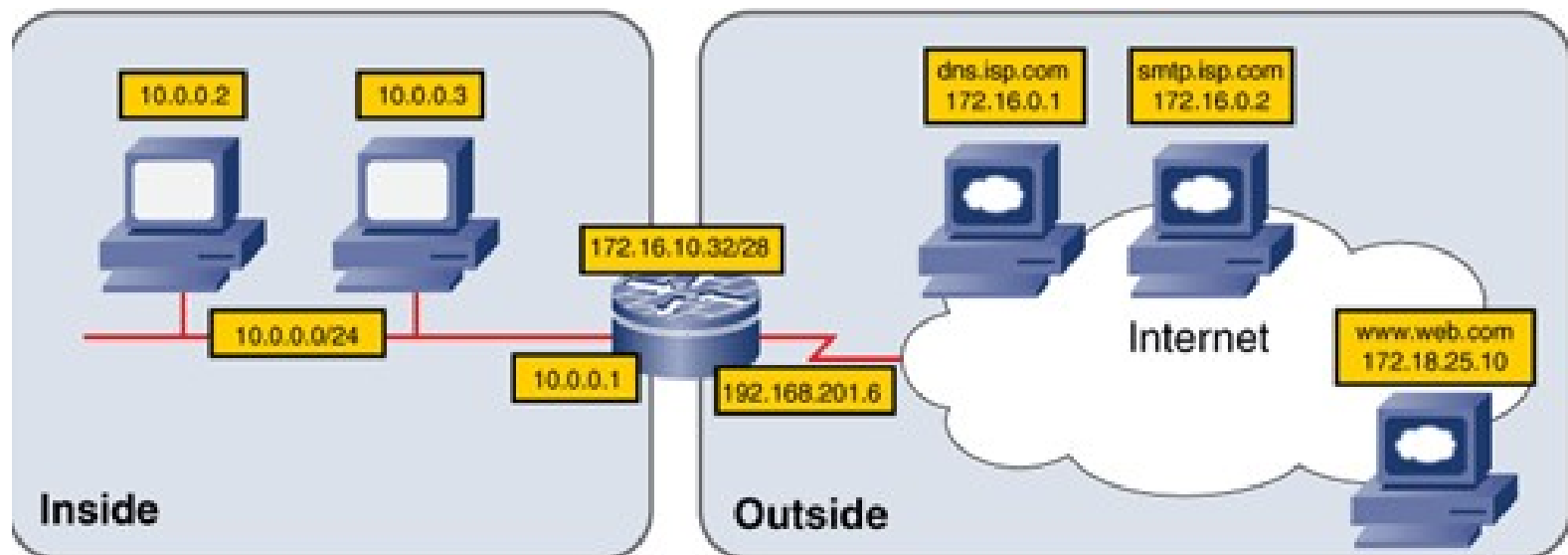
Implementing Zone-based Policy Firewall with CLI

1. Create the zones for the firewall with the `zone security` command
2. Define traffic classes with the `class-map type inspect` command



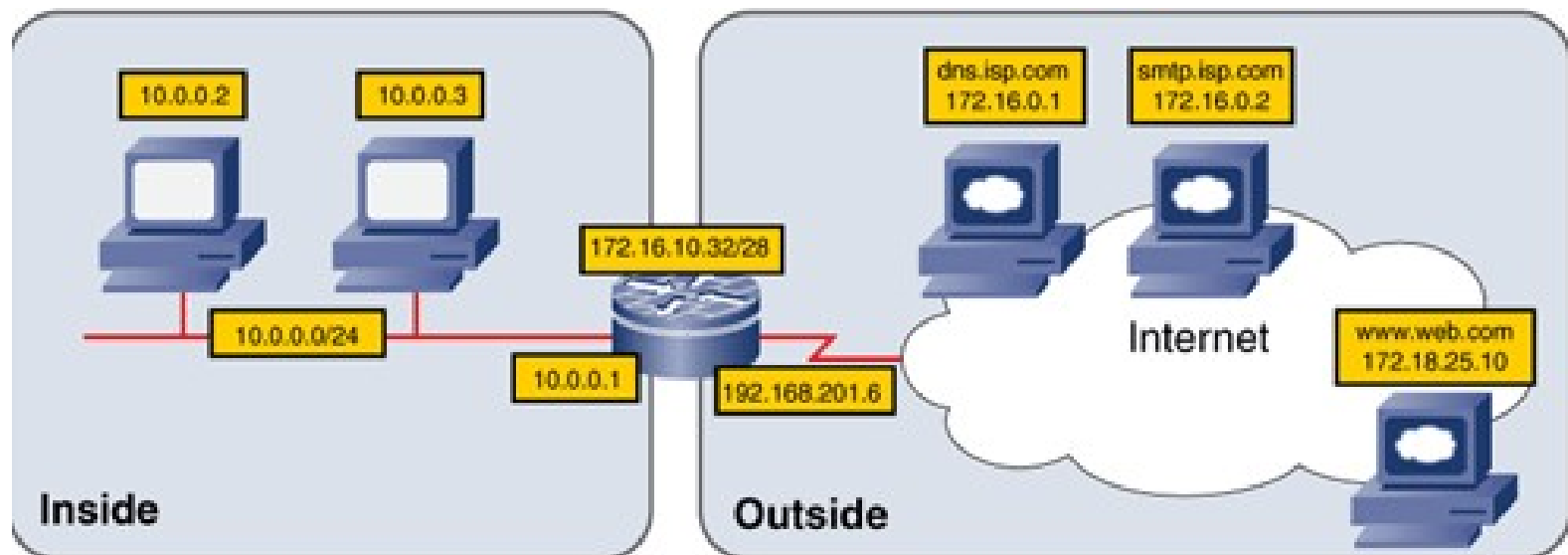
3. Specify firewall policies with the `policy-map type inspect` command
4. Apply firewall policies to pairs of source and destination zones with `zone-pair security`
5. Assign router interfaces to zones using the `zone-member security interface` command

Step 1: Create the Zones



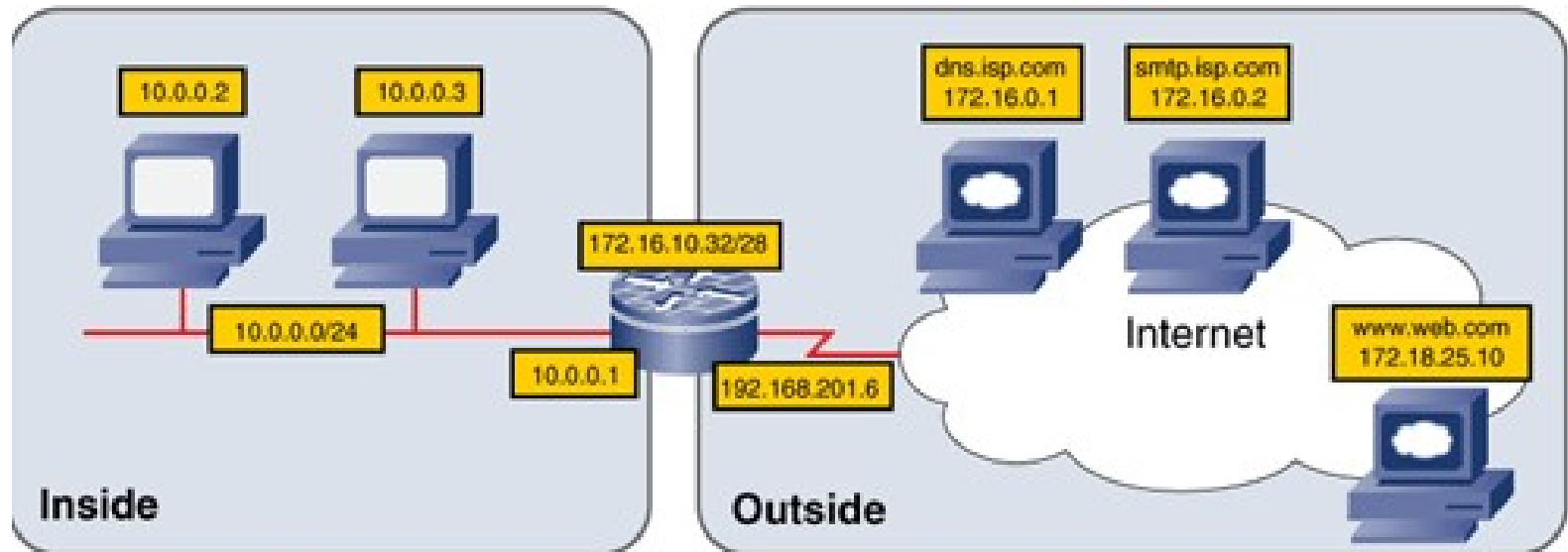
```
FW(config)# zone security Inside
FW(config-sec-zone)# description Inside network
FW(config)# zone security Outside
FW(config-sec-zone)# description Outside network
```

Step 2: Define Traffic Classes



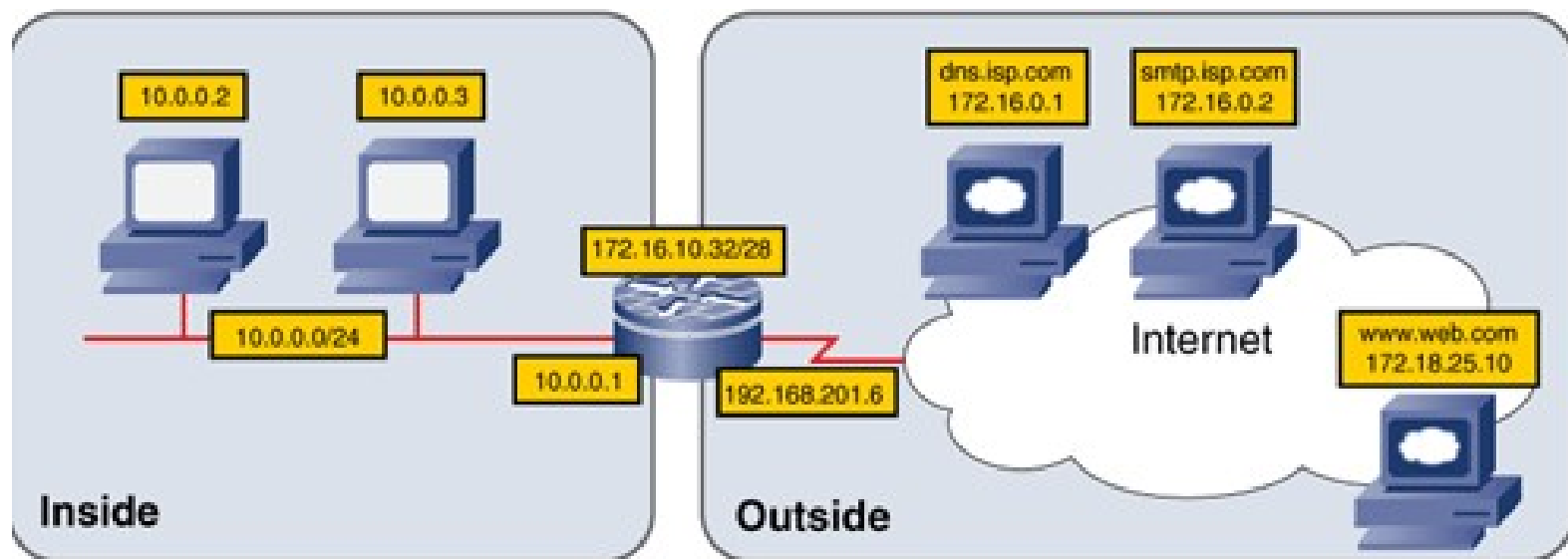
```
FW(config)# class-map type inspect FOREXAMPLE
FW(config-cmap)# match access-group 101
FW(config-cmap)# match protocol tcp
FW(config-cmap)# match protocol udp
FW(config-cmap)# match protocol icmp
FW(config-cmap)# exit
FW(config)# access-list 101 permit ip 10.0.0.0
0.0.0.255 any
```

Step 3: Define Firewall Policies



```
FW(config)# policy-map type inspect InsideToOutside
FW(config-pmap)# class type inspect FOREXAMPLE
FW(config-pmap-c)# inspect
```

Step 4: Assign Policy Maps to Zone Pairs and Assign Router Interfaces to Zones



```
FW(config)# zone-pair security InsideToOutside source Inside
destination Outside
FW(config-sec-zone-pair)# description Internet Access
FW(config-sec-zone-pair)# service-policy type inspect
InsideToOutside
FW(config-sec-zone-pair)# interface F0/0
FW(config-if)# zone-member security Inside
FW(config-if)# interface S0/0/0.100 point-to-point
FW(config-if)# zone-member security Outside
```

Final ZPF Configuration



```
policy-map type inspect InsideToOutside class
class-default inspect
!
zone security Inside description Inside
network
zone security Outside description Outside
network
zone-pair security InsideToOutside source
Inside destination Outside
  service-policy type inspect InsideToOutside
!
interface FastEthernet0/0 zone-member
security Inside
!
interface Serial0/0/0.100 point-to-point
zone-member security Outside
```

Manually Implementing Zone-based Policy Firewall with SDM



- Step 1: Define zones
- Step 2: Configure class maps to describe traffic between zones
- Step 3: Create policy maps to apply actions to the traffic of the class maps
- Step 4: Define zone pairs and assign policy maps to the zone pairs

Define Zones

1. Choose Configure > Additional Tasks > Zones

The screenshot shows the Cisco Router and Security Device Manager (SDM) interface. The 'Configure' tab is selected, and the 'Additional Tasks' pane on the left shows the 'Zones' folder expanded. The 'Add a Zone' dialog box is open, with 'Inside' entered in the 'Zone Name' field. The 'Interface' list shows 'FastEthernet0/0' selected with a checkmark, while 'FastEthernet0/1' and 'Serial0/0/0' are unselected. The 'Add...' button is highlighted in the top right of the main window.

2. Click Add

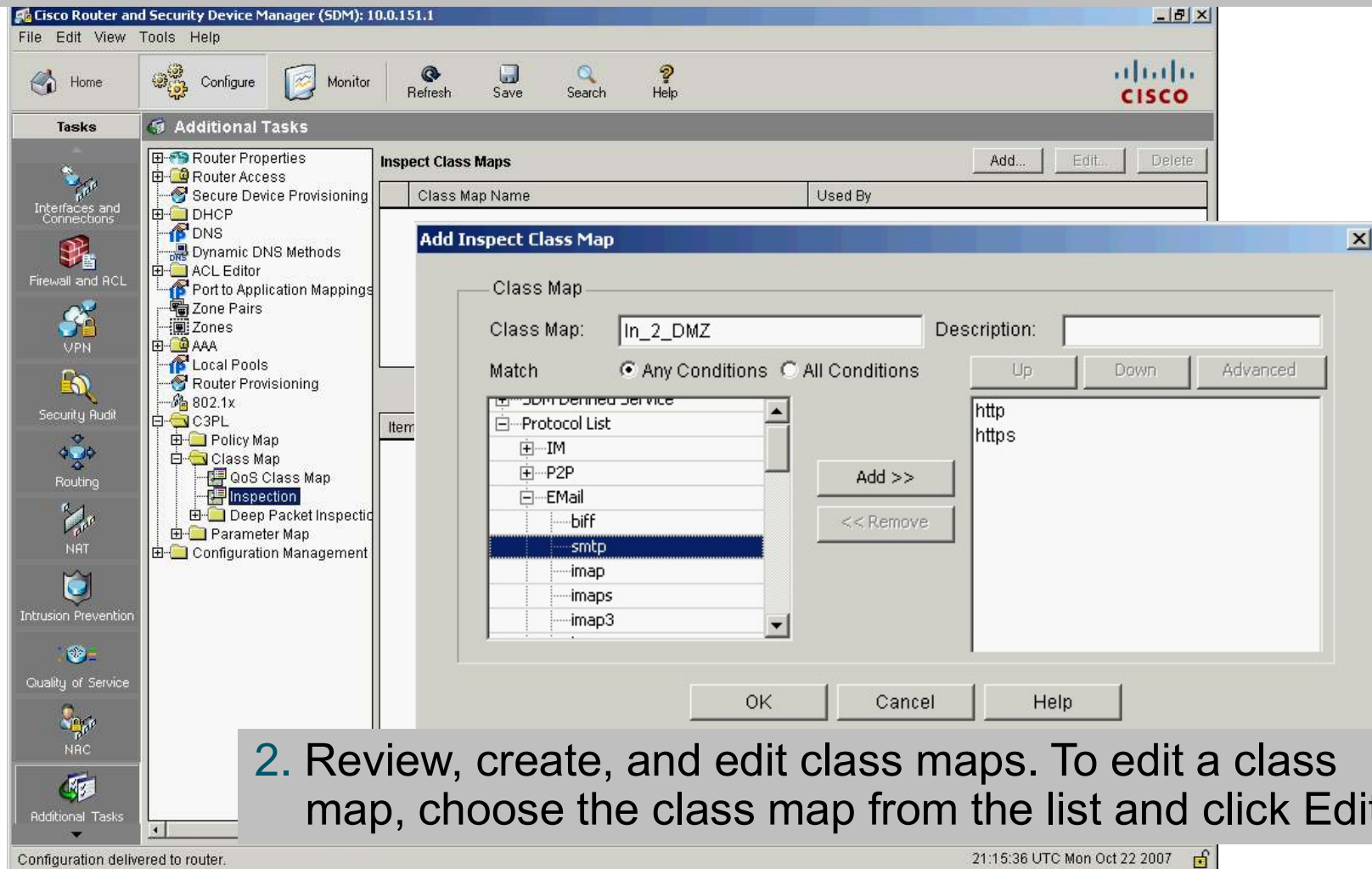
3. Enter a zone name

4. Choose the interfaces for this zone

5. Click OK to create the zone and click OK at the Commands Delivery Status window

Configure Class Maps

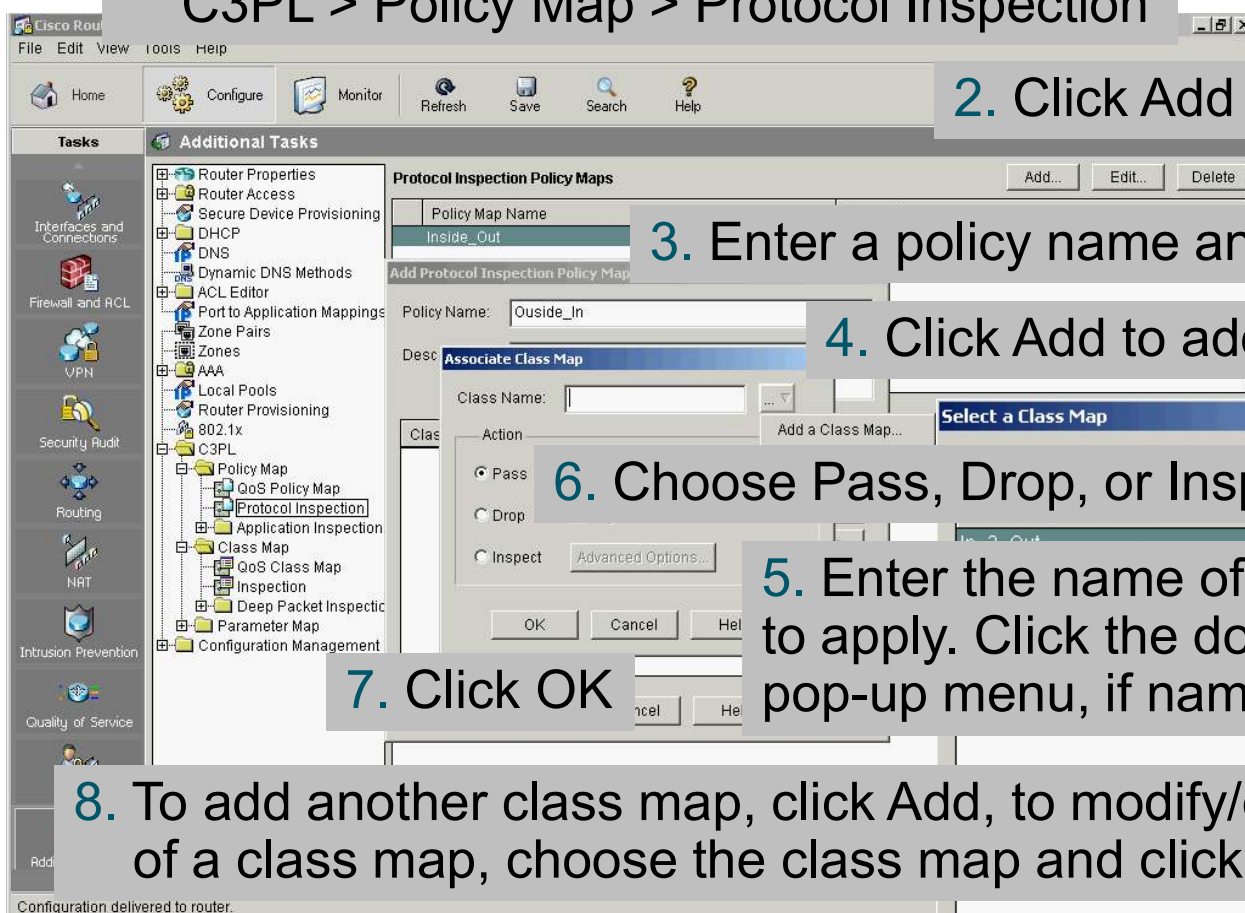
1. Choose Configure > Additional Tasks > C3PL > Class Map > Inspections



2. Review, create, and edit class maps. To edit a class map, choose the class map from the list and click Edit

Create Policy Maps

1. Choose Configure > Additional Tasks > C3PL > Policy Map > Protocol Inspection



2. Click Add

3. Enter a policy name and description

4. Click Add to add a new class map

6. Choose Pass, Drop, or Inspect

5. Enter the name of the class map to apply. Click the down arrow for a pop-up menu, if name unknown

7. Click OK

8. To add another class map, click Add, to modify/delete the actions of a class map, choose the class map and click Edit/Delete

9. Click OK. At the Command Delivery Status window, click OK

Define Zone Pairs

1. Choose Configure > Additional Tasks > Zone Pairs

The screenshot shows the Cisco Router and Security Device Manager (SDM) interface. The 'Configure' tab is active, and the 'Additional Tasks' pane on the left is expanded to 'Zone Pairs'. The 'Add a Zone Pair' dialog box is open, showing the following fields:

- Zone Pair: In_to_Out
- Source zone: Inside
- Destination zone: Outside
- Policy: Inside_Out

The 'Add a Zone Pair' dialog box has 'OK', 'Cancel', and 'Help' buttons at the bottom. The 'Add...' button in the 'Zone Pairs' table is highlighted.

2. Click Add

3. Enter a name for the zone pair. Choose a source zone, a destination zone and a policy

4. Click OK and click OK in the Command Delivery Status window

Configuration delivered to router. 21:53:18 UTC Mon Oct 22 2007

Accessing the Basic Firewall Configuration

1. Choose Configuration > Firewall and ACL

The screenshot displays the Cisco Router and Security Device Manager (SDM) interface. The title bar indicates the version is 10.0.151.1. The menu bar includes File, Edit, View, Tools, and Help. The toolbar contains icons for Home, Configure, Monitor, Refresh, Save, Search, and Help. The left sidebar shows a 'Tasks' pane with various configuration options: Interfaces and Connections, Firewall and ACL (selected), VPN, Security Audit, Routing, NAT, Intrusion Prevention, Quality of Service, NAC, and Additional Tasks. The main content area is titled 'Firewall' and shows a 'Create Firewall' wizard. A large text box contains the following information:

2. Click the Basic Firewall option and click Launch the Selected Task button

SDM can help you create a firewall task.

Basic Firewall

Use Basic Firewall to configure a firewall on a supported interface.

Advanced Firewall

Use Advanced Firewall to configure a firewall on a supported interface.

Basic Firewall will allow you to secure your Internet access (router) and easily. It uses pre-defined rules to allow private network users to access the Internet, and protects your private network from the most common outside attacks.

Basic Firewall:

- * Applies default policies to inside (trusted) and outside (untrusted) zones.
- * Inspect TCP, UDP and other protocols from inside zone to outside zone, as well as router-generated ICMP traffic.
- * Block http port-misuse for im, p2p as well as block all msn, yahoo, aol servers and write the event to log.
- * Deny traffic from outside zones to inside zones.

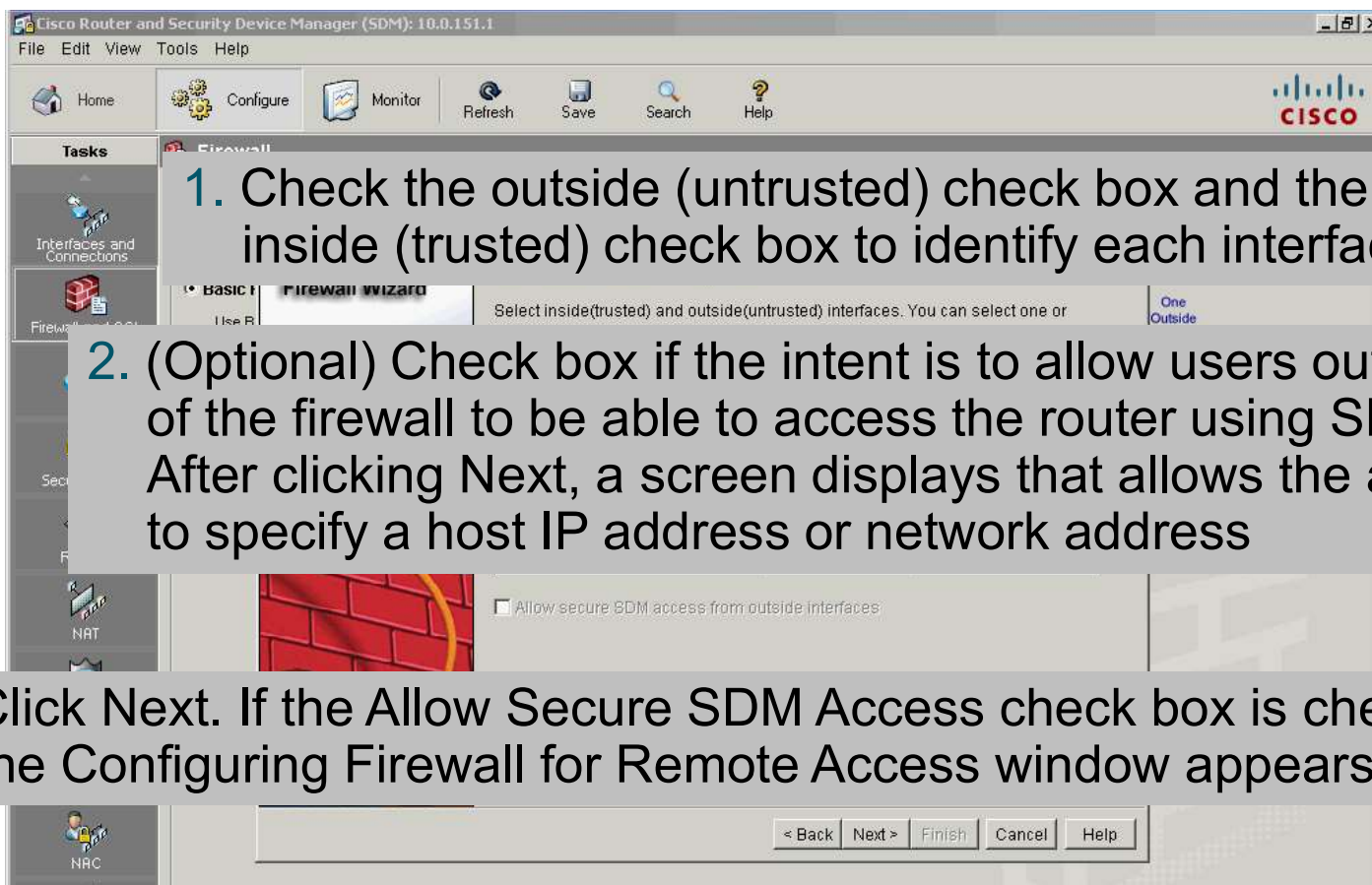
To continue, click Next.

3. Click Next to begin configuration

The wizard includes a diagram showing a computer connected to a router, which is connected to the Internet. The 'Next' button is highlighted.

How do I: How Do I Configure a Firewall on an Unsupported Interface? Go

Configuring a Firewall



1. Check the outside (untrusted) check box and the inside (trusted) check box to identify each interface

2. (Optional) Check box if the intent is to allow users outside of the firewall to be able to access the router using SDM. After clicking Next, a screen displays that allows the admin to specify a host IP address or network address

3. Click Next. If the Allow Secure SDM Access check box is checked, the Configuring Firewall for Remote Access window appears

4. From the Configuring Firewall choose Network address, Host Ip address or any from the Type drop-down list

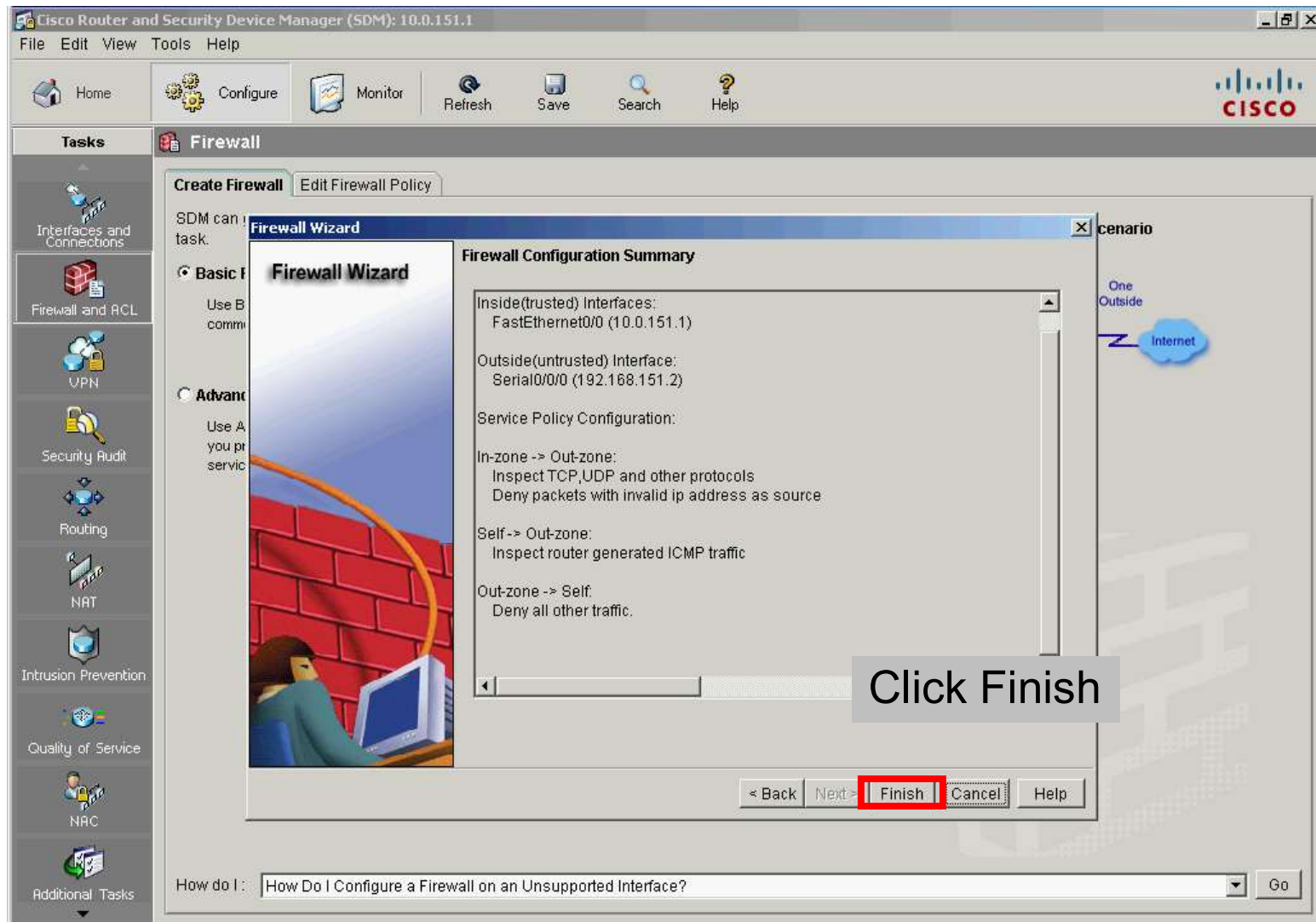
Basic Firewall Security Configuration

The screenshot displays the Cisco Router and Security Device Manager (SDM) interface. The top menu bar includes File, Edit, View, Tools, and Help. Below the menu is a toolbar with icons for Home, Configure, Monitor, Refresh, Save, Search, and Help. The left sidebar shows a 'Tasks' pane with icons for Interfaces and Connections, Firewall and ACL, VPN, Security Audit, Routing, NAT, Intrusion Prevention, Quality of Service, NAC, and Additional Tasks. The main area is titled 'Firewall' and contains two tabs: 'Create Firewall' and 'Edit Firewall Policy'. The 'Create Firewall' tab is active, showing the 'Firewall Wizard' dialog box. The wizard has two sections: 'Basic Firewall Security Configuration' and 'Advanced Firewall Configuration'. The 'Basic' section is selected, and a slider is used to choose a security level. The 'Low Security' level is currently selected. A description box states: 'The router does not identify application-specific traffic. Returns TCP and UDP'. A 'Preview Commands...' button is visible. At the bottom of the wizard, there are navigation buttons: '< Back', 'Next >', 'Finish', 'Cancel', and 'Help'. Below the wizard, there is a 'How do I:' dropdown menu with the text 'How Do I Configure a Firewall on an Unsupported Interface?' and a 'Go' button.

1. Select the security level

2. Click the Preview Commands Button to view the IOS commands

Firewall Configuration Summary



Reviewing Policy

1. Choose Configure > Firewall and ACL

2. Click Edit Firewall Policy tab

The screenshot shows the Cisco Router and Security Device Manager (SDM) interface. The 'Firewall' tab is selected, and the 'Edit Firewall Policy' sub-tab is active. The interface includes a menu bar (File, Edit, View, Tools, Help) and a toolbar with icons for Home, Configure, Monitor, Refresh, Save, Search, and Help. A left-hand navigation pane lists various tasks: Interfaces and Connections, Firewall and ACL, VPN, Security Audit, Routing, NAT, Intrusion Prevention, Quality of Service, NAC, and Additional Tasks. The main area displays a table of firewall rules. The table has columns for ID, Source, Destination, Service, Action, Rule Options, and Description. Two rule sets are visible: 'Inside_Out (Inside to Outside, Inside to DMZ)' and 'Outside_In (Outside to DMZ)'. The 'Rule Flow Diagram' at the bottom shows traffic flow from 'Inside,Inside' to 'Outside,DMZ' through a router icon. The status bar at the bottom indicates 'Firewall and ACL' and the time '22:28:23 UTC Mon Oct 22 2007'.

ID	Source	Destination	Service	Action	Rule Options	Description
Inside_Out (Inside to Outside, Inside to DMZ)						
1	any	any	tcp udp icmp	Permit ACL		
2	any	any	In_2_DMZ	Permit ACL		
Outside_In (Outside to DMZ)						
1	any	any	http ftp	Permit Firewall		

Rule Flow Diagram

Inside,Inside → [Router] → Outside,DMZ

Apply Changes Discard Changes

CLI Generated Output

```
class-map type inspect match-any iinsprotocols
  match protocol http
  match protocol smtp
  match protocol ftp
!
policy-map type inspect iinspolicy
  class type inspect iinsprotocols
  inspect
!
zone security private
zone security internet
!
interface fastethernet 0/0
  zone-member security private
!
interface serial 0/0/0
  zone-member security internet
!
zone-pair security priv-to-internet source private destination internet
  service-policy type inspect iinspolicy
!
```

List of
services
defined in the
firewall policy

Apply action (inspect =
stateful inspection)

Zones created

Interfaces assigned to
zones

Inspection applied
from private to
public zones

Firewall Status Information

1. Choose Monitor > Firewall Status

The screenshot shows the Cisco Firewall Status monitoring interface. The left sidebar contains a 'Tasks' menu with icons for Overview, Interface Status, Firewall Status (selected), VPN Status, Traffic Status, QoS Status, NAC Status, Logging, IPS Status, and 802.1x Status. The main content area is titled 'Firewall Status' and includes a 'Select the firewall policy to view details' section with a table of zone-pairs. Below this is a 'View Interval' dropdown set to 'Real-time data every 10 sec' and a 'Stop Monitoring' button. At the bottom, there are tabs for 'Active Sessions', 'Dropped Packets', and 'Allowed Packets', with a table for 'Active Sessions' showing columns for Traffic Type, Source IP, and Destination IP. The status bar at the bottom right shows the time '22:28:47 UTC Mon Oct 22 2007'.

Zone-pair Name	Policy Name	Source Zone	Destination Zone
In_to_Out	Inside_Out	Inside	Outside
Out_to_DMZ	Outside_In	Outside	DMZ
In_to_DMZ	Inside_Out	Inside	DMZ

Traffic Type	Source IP	Destination IP
--------------	-----------	----------------

2. Choose one of the following options:

- Real-time data every 10 sec
- 60 minutes of data polled every 1 minute
- 12 hours of data polled every 12 minutes

Display Active Connection



```
Router# show policy-map type inspect zone-pair session
```

- Shows zone-based policy firewall session statistics

